ARCHITECTURE RESEARCH · PHASE 1 · OCTOBER 2026

Vault

A computer that only its owner, and the successors they name, can use. It verifies who is at the keyboard continuously and handles coercion without endangering the operator. Built first for the people who hold the keys to frontier AI models.

Prepared by Pablo Peniche **Status** Draft for discussion · not for distribution **Sources** 205, numbered inline

BOTTOM LINE

Vault should build the secretless terminal first.

Vault should build first a hybrid architecture: a dedicated terminal that never holds model weights or long-lived secrets, a secure element cryptographically paired to the terminal's sensors that matches the operator's biometric on-device and signs a steady stream of short-lived presence attestations, and a lab-controlled verifier that keeps a seconds-scale session key alive inside the confidential-computing environment holding the weights only while those attestations keep arriving. Any irreversible, high-impact action (bulk export, a new egress destination, a change to the quorum or the heir list) additionally needs a biometric-bound K-of-N quorum and a time delay. The case rests on a specific gap. Frontier labs' published controls verify possession of a token and approval by a second person, but none publicly verifies that the enrolled human is the one at the terminal for the whole session, or that the human is acting freely, even though RAND scores bribery and extortion of insiders as 60–80% likely to succeed against organized-crime and standard state attackers[1, 2, 3]. No single architecture closes that gap. Software agents share a privilege domain with the attacker, hardware biometrics authenticate only at a point in time, confidential computing protects weights but has no notion of a human, and keys derived from biometrics top out around 72–84 bits[4, 5, 6, 7]. Duress should be handled the way vault locks, pharmacies and hardware wallets handle it: an explicit covert signal, silent and indistinguishable degradation, and quorum plus delay so that no single coerced person can deliver the payoff. Stress inference is the wrong tool; it fails statistically, and for employees in the EU it is presumptively prohibited under AI Act Art. 5(1)(f) when the purpose is protecting property[8, 9, 10]. Succession, whether to a founder's heirs or to a lab's successor operators, is a key-ceremony problem (owner-signed delegation, quorum, veto windows and a non-biometric break-glass path), never a biological one. The buyer set is small, an estimated 5–12 frontier developers plus a ring of infrastructure and government holders, but no shipping product found in this research combines continuous hardware-attested human binding, co-presence, duress handling and weight-egress integration.

Labelling conventions used throughout: "vendor claim" marks a figure published by a vendor and not independently evaluated; "secondary" marks news, aggregator or search-summary coverage that was not checked against the primary source; "proposal" or "inference" marks design reasoning produced by this research rather than established fact.

01 · EXECUTIVE SUMMARY

Labs verify tokens, Vault must verify people

Making a computer usable by exactly one person, and later by the successors that person names, breaks into four problems that the evidence treats very differently. **Binding** (is this the enrolled human?) is well served by mature hardware: secure elements that release a key only after an on-device match. **Continuity** (is it still the same human minutes later?) has strong components but no shipping product that signs a continuous human-presence stream into the system holding the protected asset. **Freedom** (is the human acting voluntarily?) cannot be measured reliably, so it has to be designed around rather than detected. **Succession** (who may act next?) is a cryptographic-governance problem with well-tested patterns from wallets, password managers and HSM key ceremonies. Vault's thesis follows from that split: build binding and continuity in hardware, keep the weights off the terminal entirely, make every irreversible action need several live, verified people plus a delay, give operators a covert way to signal duress, and treat succession as a quorum ceremony. Frontier AI labs are the right first market because their own reference threat model, RAND's *Securing AI Model Weights*, puts insiders and extortion at the center and asks for these properties at SL3–SL5[1].

Seven findings support the thesis:

---

01 **The gap is human binding, continuity and freedom, not cryptography.** Lab frameworks name MFA, hardware-backed authentication, managed devices and two-party approval[2, 3, 11]. None publicly commits to biometric-bound or continuously verified operator identity, or to duress controls. Meanwhile RAND scores "bribes and cooperation" and "extortion" at 4 on its 5-point scale (60–80% chance of success) for organized-crime and standard state attackers[1]. This research found no shipping product that combines continuous, hardware-attested human presence with confidential-computing session teardown, co-presence and duress handling. That is absence of evidence from a search, not proof.

---

02 **No single architecture is enough; a specific hybrid is.** Software agents share the attacker's privilege domain; SentinelOne's incident data show security tools disabled in about 48% of 2024 intrusions[4]. Hardware biometrics gate key use, but only at a moment[5, 12]. Confidential computing protects weights from administrators but knows nothing about humans[6, 13]. Biometric-derived keys reach only about 72 bits (fingerprint) and 84 bits (face)[7]. HSM and MPC quorums bind shares to cards and PINs, not to people[14, 15]. The recommended hybrid combines a secretless terminal (A3), sensor-paired secure-element matching (A2) and biometric-bound quorum (A5). Software telemetry (A1) may only reduce privilege, and biometric cryptosystems (A4) are confined to template privacy.

---

03 **3D face on an authenticated sensor path is the only accurate, passive continuity signal.** NIST face evaluations show the matcher is not the bottleneck: leading 1:1 algorithms reach roughly 0.14–0.16% false non-match on cooperative border and visa images, per a trade-press summary[16]. Capture conditions and spoofing are the bottleneck. Vein, iris and fingerprint suit explicit step-up checks. Behavioral signals need about 18 seconds to several minutes, or hundreds of actions, to flag an impostor[17, 18]. NIST SP 800-63B-4 bars voice outright[19].

---

04 **Injection, not masks, is the attack to engineer against.** Vendor threat data report native virtual-camera attacks up 2,665% in 2024[20]. FIDO's v4.1 biometric certification sets no numeric threshold for injection[21], and the first injection-detection standard, CEN/TS 18099, is only provisional[22]. The dependable defense is architectural: a firmware-locked sensor whose output is authenticated to the secure element, as Apple and Windows ESS already do[23, 12].

05 **Duress must be signaled, not inferred, and coercion must be made unprofitable.** The benchmark lab stress classifier reaches 93% binary accuracy on 15 subjects[24]. Field performance drops sharply[25, 26], no dataset covers real coercion, and base rates guarantee that inferred alarms are mostly false[27, 28]. The battle-tested pattern is explicit covert signals (duress PINs, fingers, codes), silent and indistinguishable degradation, two-person rules and time delays[9, 29, 30].

06 **Law points to the same design.** EU AI Act Art. 5(1)(f) presumptively prohibits inferring employees' stress or anxiety from biometric signals. The Commission reads the safety exception as covering life and health, "not … property against theft or fraud"[10]. On-device 1:1 verification is the best-supported position under GDPR and the AI Act[31, 32, 10], and it limits, but does not eliminate, BIPA exposure[33].

07 **Succession is a key ceremony, never biology.** Every shipping inheritance product pairs cryptography with a waiting period and a human or legal attestation[34, 35, 36]. DNA is slow, not secret, unreliable for half-siblings and legally toxic for US employers[37, 38, 39, 40]. In a lab, "heirs" are successor operators under M-of-N custodianship, with a non-biometric break-glass path[41, 42].

Six adversaries converge on the authenticated session

RAND's framework is the reference threat model for weight security, and it defines each security level by the attacker it defeats. SL3 must stop "cybercrime syndicates or insider threats (OC3)", SL4 "most standard operations by leading cyber-capable institutions", and SL5 "most top-priority operations by the top cyber-capable institutions"[1]. Its catalogue of about 38 attack vectors includes compromising existing credentials, undermining the access-control system itself, falling back to "alternative (less secure) authentication or access schemes", evading physical access control, and the human-intelligence vectors of bribery, extortion and candidate placement[1]. The six threat classes below regroup those vectors around the one asset Vault controls: the authenticated session.

Insiders. RAND groups insiders with crime syndicates "because the level of investment required to robustly defend against them" is comparable. It says a key goal of SL3 is reducing insider risk, which "simultaneously reduces the risk from attackers who can masquerade as insiders"[1]. Labs acknowledge the gap. Anthropic amended its ASL-3 standard in May 2025 to exclude "both sophisticated insiders and state-compromised insiders"[43]. Its RSP v3.0 sets an aspiration, at automated-AI-R&D capability, of controls on employees "up to and including the company's CEO"[44]. The incident record is insider-heavy. Former Google engineer Linwei Ding was convicted in January 2026 on seven counts of economic espionage and seven of theft of trade secrets, after uploading more than two thousand pages of AI-infrastructure secrets to a personal cloud account over about a year[45]. News coverage of the indictment reported an allegation that a colleague repeatedly scanned Ding's badge while he was in China[46]. Meta's LLaMA weights, distributed to vetted researchers, appeared on 4chan and BitTorrent within days in March 2023[47]. Ding took design documents, not weights, but the failure mode generalizes: presence was proven by possession (a badge), possession was delegated, and nothing verified that the credential holder was the person acting.

Coercion (the "$5 wrench"). RAND describes extortion that threatens "physical harm, legal harm, financial harm" and notes that "leverage can also be applied to friends and family of the target". It scores extortion 4 of 5 for OC3 and OC4 attackers and 5 for OC5[1]. Yet its only SL5 countermeasure is "proactive protection" of staff through guards and counterintelligence[1]; the reference framework contains no technical duress control. The best public quantitative proxy comes from a different population. Jameson Lopp's catalogue of about 225 verified physical attacks on cryptocurrency holders (a conference-talk transcript, secondary) finds about 66% succeed, nearly 25% are home invasions and about 23% are kidnappings[48]. Irish "tiger kidnappings", in which bank staff or their families were held hostage to force a staff member to remove cash, show the hardest variant: the operator arrives alone, calm-looking and fully authenticated. The parliamentary record of that response protocol could only be partially verified[49]. No source quantifies how often AI-lab operators are coerced.

Session hijack after login. Most access systems authenticate once and then trust the session. Microsoft Entra Continuous Access Evaluation propagates critical revocation events with latency "up to 15 minutes" and issues session tokens valid for up to 28 hours[50]. Teleport's documentation concedes that per-session MFA "does not block a compromised credential from running other actions"[51]. NIST SP 800-63B-4 caps AAL3 sessions at 12 hours, with a recommended 15-minute inactivity timeout, and does not describe continuous biometric authentication at all[19]. RAND asks for more as early as SL2: FIDO authentication "either for every interaction or for any action that is attempted after a short period (e.g., 60 seconds)"[1]. Bojinov et al. add the coercion twist: with remote authentication, "an attacker could coerce a trained user to authenticate to a remote server and then hijack the session"[52].

Deepfake and injection presentation attacks. CEN/TS 18099 separates injection from presentation attacks on the sensor. Injection means feeding synthetic or replayed data into the pipeline through virtual cameras, emulators, hooked functions or manipulated traffic[22]. A vendor certified for ISO/IEC 30107-3 presentation-attack detection (PAD) may still be

vulnerable to injection, according to a vendor blog[53]. iProov's threat report, a vendor source, counts native virtual-camera attacks up 2,665% and face swaps up 300% in 2024[20]. Real-world deepfakes already move money: engineering firm Arup reportedly lost about US$25M after an employee joined a video call in which every "colleague" was synthetic (news coverage)[54]. Local hardware injection is proven too. CyberArk's custom USB device fed Windows Hello a single valid IR frame and unlocked the PC (CVE-2021-34466)[55].

Lost or stolen device and physical tampering. Blackwing Intelligence, commissioned by Microsoft, found three "100 percent reliable" bypasses of match-on-chip fingerprint sensors on Dell, Lenovo and Surface hardware. Each needed physical access and a small man-in-the-middle device, and vendors have since patched them[56]. On the server side, TEE.fail (disclosed October 2025, IEEE S&P '26) used a DDR5 bus interposer that "should cost you under $1000". It extracted Intel's provisioning certification key, forged TDX attestations and "borrowed" NVIDIA GPU attestations. Intel and AMD treat physical interposers as out of scope[57, 58]. Apple's Stolen Device Protection shows the consumer mitigation pattern for changing recovery contacts or enrolled biometrics away from familiar locations: biometric, a one-hour security delay, then biometric again[59].

OS and administrator compromise. SentinelOne's incident data show security tools disabled in about 48% of 2024 intrusions, and "EDR killers" are now a maintained capability bundled into ransomware-as-a-service[4]. Singapore's CSA documented an EDR killer that loads a signed vulnerable driver to blind endpoint protection[60]. At Black Hat 2025, ERNW showed that a local administrator could insert biometric data into the Windows Hello database, which is protected only by CryptProtectData, so that any face unlocked the victim's PC. The hypervisor-isolated Enhanced Sign-in Security (ESS) mode blocks the attack, but not all hardware supports it[61].

THREAT	REPRESENTATIVE EVIDENCE	WHAT DEFEATS IT	VAULT LAYER
Insider using legitimate access	Ding conviction[45]; LLaMA leak[47]	Non-transferable, per-action biometric binding; headcount caps; quorum for copies	A2 + A5
Coercion of operator or family	RAND extortion score 4–5 of 5[1]; wrench-attack catalogue (secondary)[48]	No single person can deliver the payoff; covert duress signal; silent degradation	A5 + duress layer
Session hijack after login	CAE latency up to 15 min, tokens up to 28 h[50]	Seconds-scale session key kept alive only by fresh human attestations	A3 + A2
Deepfake / injection	Virtual-camera attacks +2,665% (vendor)[20]; CVE-2021-34466[55]	Authenticated sensor-to-secure-element path; no USB or virtual cameras	A2
Lost/stolen device, physical tamper	Match-on-chip MITM[56]; TEE.fail[57]	Secretless terminal; tamper-responsive attestation key; facility controls	A3 + FIPS 140-3 L3 element
OS / admin compromise	Security tools disabled in ~48% of intrusions[4]; Hello template injection[61]	Enforcement outside the endpoint OS; fail-closed heartbeat	A3 (A1 as telemetry only)

Every class attacks either the moment after authentication or the path between a sensor and the decision it feeds. That yields four design principles applied in the rest of this report: keep secrets off the endpoint, authenticate the sensor path, fail closed when evidence stops arriving, and require more than one live human for anything irreversible. The geopolitical temperature is rising. News coverage of a July 2026 House Intelligence hearing reported witnesses saying China's MSS "now looks at frontier model companies"[62]. In October 2026, per news coverage, Proofpoint attributed to the China-aligned group TA419 a campaign that impersonated a senior Anthropic employee[63].

Each fails alone, together they cover SL3–SL4

A1. A software agent on a commodity OS is a sensor, not a lock

Continuous webcam and behavioral authentication delivered as an agent on macOS, Windows or Linux already ships. SecureAuth SessionGuardian runs "periodic facial checks" across browser, desktop and VDI sessions, and locks on "additional or unknown faces in the frame". Its documentation (vendor) does not state the check interval, where matching happens, or any liveness or injection defenses[64]. OLOID markets presence detection that locks devices when users step away (vendor)[65]. This research found no independent evaluation of either. The structural problem is that attacker and enforcer share a privilege domain: whoever holds admin or kernel rights can kill the agent, feed it injected frames, or tamper with its template store, as the EDR-killer and Windows Hello results above show[4, 61]. A commodity webcam has no authenticated path to the matcher. FIDO's biometric certification only asks vendors to document injection countermeasures, which the lab then checks; it sets no measured threshold[21]. NIST SP 800-63B-4 requires that the biometric "be presented and compared for each authentication operation" and says verifiers SHOULD check sensor integrity, for example through signed attestation[19]. The research notes conclude (inference) that A1 belongs in Vault only as telemetry: fast absence detection, a second-face alarm and behavioral anomaly scoring. Its output may only *reduce* privilege, and the server must treat a missing heartbeat as revocation so that killing the agent fails closed.

A2. Hardware-rooted matching gates keys, but only at a moment

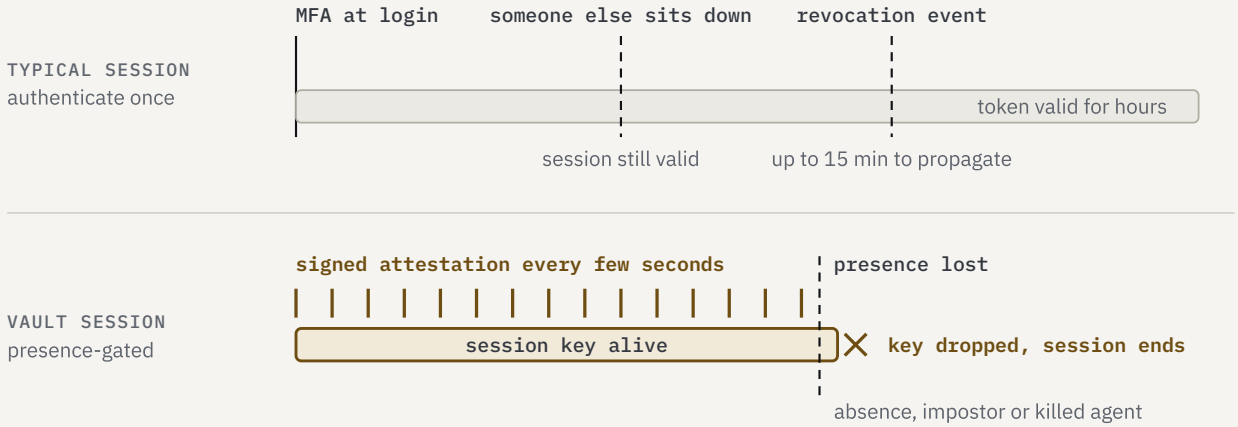
The key distinction is whether a match **releases a key inside a secure element** or merely **returns a boolean to the OS**. Apple's Touch ID sensor talks to the Secure Enclave over a channel encrypted and authenticated with AES-CCM using a per-sensor, factory-provisioned key, so the application processor forwards data it "can't read". Face ID capture data are "digitally signed and sent to the Secure Enclave"[23]. On a match, the biometric subsystem "provides the key for unwrapping the Data Protection keys". Keychain items can be released "only by a successful match", and app-created Secure Enclave keys are used only inside the enclave "after it authorizes their use". The plain app API, by contrast, only reports "whether the authentication was successful"[5]. Windows ESS runs the face matcher under virtualization-based security, lets only the face camera write into hypervisor-protected memory, requires match-on-sensor fingerprint readers with a Microsoft certificate burned in at manufacture, and uses a boot-time secure channel to the TPM to "authorize the usage of Windows Hello keys". ESS face does not support external cameras, and on multi-user devices "the lowest Windows Hello security posture applies"[12]. Android's Class 3 biometrics can gate per-operation Keystore keys while Class 2 cannot[66]. YubiKey Bio stores and matches fingerprints on a separate secure element (vendor claim)[67]. Apple claims a random-person false-match rate below 1 in 1,000,000 for Face ID and below 1 in 50,000 for Touch ID (vendor claim)[68]. FIDO's lab-measured BioLevel 2 bound is 1:10,000, which is the same as NIST's floor[21, 19]. The weakness is time: every shipping design matches on an explicit event and then hands an unlocked session to a general-purpose OS, and this research found no public API for continuous Secure Enclave face re-verification on macOS. The strongest pattern, per the notes' inference, is a non-exportable signing key inside the secure element whose every use requires a fresh match. Each presence attestation in A3 would be signed that way.

A3. A secretless terminal plus confidential computing has a server half but no human half

The server half ships today. NVIDIA H100 confidential-computing mode is attested through NVIDIA's Remote Attestation Service, which returns a JWT[69]. GPU confidential computing relies on a CPU confidential VM (Intel TDX or AMD SEV-SNP)[70]. Azure confidential VMs with H100 reached general availability in September 2024[71], and Google Cloud's A3

confidential VMs with H100 are generally available[72]. An independent benchmark found low overhead for LLM inference that shrinks with model size, near zero at 70B parameters[73]. Anthropic and Pattern Labs (now Irregular) published a design (vendor research) in which weights are "stored encrypted, decrypted at the loader, and never released from there", and a keyserver releases decryption keys only to an environment whose attestation proves isolation, signed code and disabled debugging[6]. Fortanix sells a product that releases weights only after composite CPU+GPU attestation (vendor claim)[74]. IETF RATS (RFC 9334) supplies the vocabulary: Attester, Verifier, Relying Party, freshness through nonces, timestamps or epoch IDs, and a Hardware Watchdog use case in which a device lacking "regular and fresh Attestation Results" is forced to reboot. RFC 9334 does not address attesting humans[13].

The human half does not exist as a product. The closest analogs are event-driven revocation (Entra CAE)[50], per-session MFA and live moderated sessions in Teleport[75], periodic face-check agents[64], research on TEE-based "process attestation" of continuous human activity[76], and a 2019 DISA pilot of chipsets that continuously verified users by gait, face, voice and location, whose production status is unknown[77]. The notes infer that Vault maps cleanly onto RATS. The terminal's secure element is the Attester, emitting evidence that combines a fresh match result, the measured boot state and the current epoch. A lab-controlled Verifier appraises that evidence, and the confidential VM or the keyserver is the Relying Party, which drops the session key when no fresh result arrives within T seconds. Residual risks remain. The terminal still displays outputs. The presence signal is only as strong as the A2 sensor path. TEE.fail shows server attestations can be forged with physical access, and NVIDIA GPU reports are not bound to a specific CVM, so the Verifier must appraise CPU and GPU evidence as one bound composite and facility controls stay in the trusted base[57].



Authenticate once vs. stay authenticated. Most access systems check identity at login and then trust the session for hours. Microsoft Entra's continuous access evaluation, for example, takes up to 15 minutes to propagate a revocation[50]. In the proposed Vault design, the session key lives only while fresh, hardware-signed presence attestations keep arriving. Absence, an impostor or a killed agent all fail closed within seconds.

A4. Biometric cryptosystems are a privacy layer, not a root of trust

Fuzzy extractors, fuzzy vaults and related schemes try to derive a stable key from a noisy biometric. The September 2026 state of the art ("Sample-then-Correct") says existing constructions "do not provide strong security for the biometric modalities deployed on modern devices". It improves them to about 72 bits (fingerprint), 84 bits (face) and 111 bits (iris), at a true-accept rate of roughly 90% over multiple readings and about 60% from a single reading[7]. Information-theoretic

analysis suggests that at realistic error rates sketches may leak most of a biometric's entropy[78]. Fuzzy-vault correlation attacks link a person across databases[79]. What has been deployed is secure multiparty *matching*, not key derivation. World moved iris-code uniqueness checks to SMPC in May 2024 and deleted its old iris codes[80], and Anonybit shards templates across nodes (vendor claim)[81]. The notes conclude (inference) that Vault must never derive a weight key from a biometric. A4 is useful only for privacy-preserving re-verification and cancelable templates, for example during heir enrollment or recovery.

A5. Threshold control and two-person integrity are mature but bound to cards

M-of-N quorum is standard in HSMs. Thales Luna splits authentication secrets across up to 16 PED keys[14], and Entrust nShield requires K of N administrator cards assigned to different role holders[15]. In MPC custody, Fireblocks says the private key is never assembled and that policy is enforced inside Intel SGX (vendor claim)[82], an enclave family that physical interposer attacks have since broken[57]. Two-person integrity has a formal definition: a system that prevents lone access by requiring at least two authorized people, each able to detect improper procedures[83]. Teleport offers software analogs in moderated sessions and dual authorization[75]. G42's frontier safety framework cites "multi-party and quorum-based approval for high-sensitivity operations" for weights, as quoted in an academic analysis[84]. The gap is that no shipping product found here binds each quorum share to a per-member biometric match; shares follow possession and PINs. The notes propose (inference) shares that release only on a fresh on-device match, which turns "K of N cards" into "K of N specific people". Because an MPC round per keystroke is impractical, quorum should *open* a time-limited session key and continuous presence should *keep it alive*.

Comparison and the recommended hybrid

The table below is the research notes' qualitative synthesis of the evidence above (inference, not a measured benchmark).

ARCHITECTURE	ROOT/KERNEL COMPROMISE	SENSOR INJECTION	"ADMIN KILLS IT"	PHYSICAL ATTACK	CONTINUOUS?	MATURITY	MAIN FAILURE MODES
A1 Software agent	Weak (same privilege domain)	Weak (virtual cameras)	Fails open unless server revokes on missing heartbeat	Weak	Yes, but forgeable	Shipping (vendor)	Spoofing, agent tampering, false locks
A2 HW-rooted match	Strong for key use; weak once key is released to OS	Strong if sensor is paired to the secure element	Matcher survives; post-unlock session does not	Moderate (2023 match-on-chip bypasses, patched)	No	Shipping (Apple silicon, ESS, YubiKey Bio)	Point-in-time only
A3 Secretless terminal + CC	Strong for weights (none on terminal)	Inherits A2	Fail-closed by design	Server TEEs vulnerable to interposers	Yes, if built	Server side GA; human stream must be built	Attestation forgery, freshness/delay attacks, display exfiltration

ARCHITECTURE	ROOT/KERNEL COMPROMISE	SENSOR INJECTION	"ADMIN KILLS IT"	PHYSICAL ATTACK	CONTINUOUS?	MATURITY	MAIN FAILURE MODES
A4 Biometric crypto	n/a (privacy layer)	n/a	n/a	n/a	No	SMPC matching deployed; derived keys not	44–84-bit keys, helper-data leakage
A5 Threshold / TPI	Strong against a single insider	n/a	One admin cannot kill a quorum	HSM tamper response	No (ceremony)	Mature; biometric-bound shares not shipping	Collusion, availability, ceremony overhead

The recommended hybrid uses A3 for the weights path, A2 for the human signal, A5 for quorum and two-person integrity, A1 only as privilege-reducing telemetry, and A4 only for template privacy. Mapped onto RAND's access-control benchmarks, it reaches SL3 and SL4 for the access slice. At SL5 Vault becomes one component inside facility controls rather than a solution by itself.

RAND LEVEL	RAND ACCESS-CONTROL BENCHMARK[1]	HYBRID LAYERS THAT MEET IT (INFERENCE)
SL2	FIDO authentication "for every interaction" or after ~60 s; all interactions recorded	A2 per-action signed match; A1 telemetry
SL3	Weight copying limited to 20 people, direct isolated-network access to 50, output-limited access to 100; "no one has persistent access"; at least two approvers for sensitive code changes, with no "force submit" bypass; sensitive actions delayed for security review	A2 non-transferable credentials, A5 biometric-bound quorum, enforced delays
SL4	"Secure hardware required for access"; Personnel Reliability Program-style insider program; "critical security assumptions … implemented in hardware"	Add A3: secretless terminal, attested CVM, seconds-scale session keys
SL5	"Supervised access for everyone"; protection of staff from extortion; "irrecoverable key policy"; "currently not possible"	Vault co-presence mode inside facility controls such as the SL5 Task Force draft's red/black zones, TEMPEST and bandwidth limiters[85]

Real high-security deployments today mostly combine physical access control, smartcards, session timeouts and static biometrics. Natixis deployed finger-vein authentication in trading rooms, where one authentication unlocks and locks a whole cluster of PCs; it is static, not continuous (vendor case study)[86]. FDA rules for electronic signatures already rely on "a single, continuous period of controlled system access"[87]. Continuous biometric authentication remains pilot-grade, which is both Vault's opening and its adoption risk. For a founder's personal Vault used at home, FIPS terminology calls that a "physically unprotected environment"[88]. The notes argue (inference) for stricter server-side policy there (shorter attestation lifetimes, geofencing, an extra quorum member) rather than trying to turn a laptop-class device into a Level 4 HSM.

3D face carries continuity, explicit biometrics carry assurance

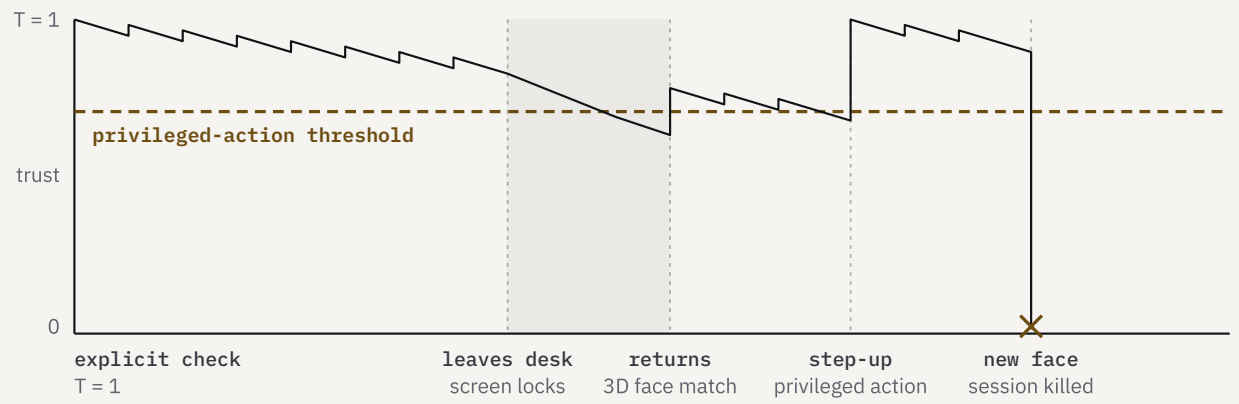
No modality is both highly accurate and truly passive at a desk. The matrix below compares what an always-on terminal could use. Accuracy figures are **not comparable across rows**. Vendor FAR claims use undisclosed protocols, while NIST figures are false non-match rates at a fixed, very low false-match rate on large galleries of cooperative images.

MODALITY	ACCURACY EVIDENCE	KNOWN ATTACKS	PASSIVE AT A DESK?	ROLE IN VAULT (INFERENCE)
3D/IR face (Face ID, Hello ESS)	Vendor claim: Face ID random-person FAR below 1 in 1,000,000[68]. NIST FRTE 1:1 leaders ~0.14% FNMR (Visa-Border) and 0.16% (Border-Border), Kiosk-Border up to 3.8% (trade-press summary of NIST)[16]	Printed IR photo against Windows Hello (2018)[89]; USB IR-frame injection, CVE-2021-34466[55]	Yes; false rejects mostly from occlusion or leaving the frame[90]	Primary continuous signal, only on an authenticated capture path
2D RGB webcam face	Same matchers; no depth	Photos, replays, virtual-camera deepfakes[20]	Yes	Telemetry only; never a trust source
Fingerprint (Touch ID, YubiKey Bio, ESS match-on-sensor)	Vendor claim: Touch ID below 1 in 50,000[68]; FIDO BioLevel 2 lab FAR 1:10,000[21]	Gelatin "gummy" fingers fooled 11 devices (2002)[91]; match-on-chip bus MITM (2023)[56]	No (touch)	Per-action key signing; not mandatory for New York staff[92]
Palm vein (PalmSecure, Amazon One)	Vendor claim: FAR below 0.00001%, FRR 0.01% with one retry[93]; Amazon One "99.9999%"[94]	Wax hands built from IR photos beat Fujitsu and Hitachi (CCC 2018)[95]	No; a palm-vein mouse exists[96]	Session start and step-up; sensor ~US$325 at reseller[97]
Finger vein (Hitachi)	Vendor claim: FAR 0.0001%, FRR 0.01%[98]	Same CCC 2018 wax-hand attack[95]	No	Step-up alternative
Iris (Optic ID, Orb)	Vendor claim: Optic ID below 1 in 1,000,000[68]; NIST-measured IrisCode FMR ~1 in 2 billion at Hamming distance 0.30[99]	Printed photo plus contact lens beat Galaxy S8 (CCC 2017)[100]	Only in a capture volume or headset	Step-up; continuous only for headset users
ECG wearable (Nymi)	Vendor claim: false positives "roughly one in 500,000" (CEO, sponsored interview)[101]; independent: ECG wearable EER below 7% within a session, below 20% across sessions[102]	ECG replay attack on Nymi, 81% success (NDSS 2017)[103]	Custody: authenticated until removed[104]	Optional custody link for short absences

MODALITY	ACCURACY EVIDENCE	KNOWN ATTACKS	PASSIVE AT A DESK?	ROLE IN VAULT (INFERENCE)
Keystroke dynamics	Vendor claim: TypingDNA FAR 0.15%, no protocol[105]; independent: impostor flagged in ~18 s[17], ~275 actions[18]; template ageing "large and systematic" over 8 weeks[106]	Mimicry not evaluated in this research	Yes	Low-weight corroboration
Mouse dynamics	Impostor flagged in ~2.4 min[17]; ~94 mouse actions[107]	Not evaluated	Yes	Low-weight corroboration
Eye movement	EER 11.25% at ~20-min re-test, 18.15% after 37 months[108]	Not evaluated	Needs eye tracker	Research only
Voice	"Biometric comparison based on voice SHALL NOT be used"[19]	Deepfake voice	Only when speaking	Excluded
EEG	EER 6.7% after 1 day rising to 14.3% after 1 year[109]	Not evaluated	Needs headset	Excluded
PPG (optical pulse)	Accuracy "declines substantially in real-world environments"[110]	Not evaluated	Wearable	Excluded

Two conclusions follow. First, the matcher is not where the risk lies. Face matching on cooperative images has converged at very low error, and the weak points are capture conditions for a seated, moving, partly occluded operator, demographic differentials, and spoofing and injection[16, 90]. A 3D/IR sensor on a hardware-authenticated path matters more than which matcher is chosen. Second, behavioral signals are too slow to be primary. At typical typing rates, windows of roughly 94–275 actions leave an impostor minutes of keyboard time before a behavioral-only lockout[18, 107]. That is unacceptable as the sole control on weight exfiltration but useful for nudging a trust score.

The literature on continuous authentication converges on score-level fusion[111] and on a trust variable that each observation raises or lowers, with lockout below a threshold and, more recently, "temporal trust decay"[90]. DARPA's Active Authentication program set the usability reference: the system may not falsely reject the user "more than five times in a row during continuous usage over a 40 hour period"[17, 112]. The notes propose a Vault trust model (proposal). A strong explicit check (vein, iris or fingerprint plus a hardware key) sets trust T to 1. T decays with a half-life of minutes. Each passive 3D-face match adds a bounded increment, a face mismatch causes a large step down, and keystroke and mouse adjust T with small weights. Privileged actions require T above a high fixed threshold, which forces a step-up when trust is stale; the fixed threshold matches NIST's requirement at the decision point[19].



Proposed trust model (a proposal, not a benchmark). An explicit check (fingerprint, palm vein or iris plus a hardware key) sets trust to 1. Trust decays over minutes, and each passive 3D-face match nudges it back up. Absence lets it fall and locks the screen. A privileged action below the threshold forces a fresh step-up check. A different face ends the session at once, without waiting for decay[17, 90].

The hardest operational distinction is **"went to get coffee" versus "impostor swapped in."** Presence sensing is not identity verification. Windows presence sensing can lock on leave and wake on approach[113], but an impostor who sits down inside the lock timeout defeats presence alone. Proposed policy (inference): lock the screen within seconds of face absence. Keep the session key alive for a short grace window only if a custody link, such as a worn band, is unbroken. Require a fresh 3D-face match on return and a full explicit check once the window lapses. Kill the session immediately, without waiting for decay, when a different face appears. Templates drift, behavioral ones most of all[106, 108], so adaptive updates should run only on samples that a strong modality co-verifies, which blocks an undetected impostor from poisoning the template (inference). Modality choice also has legal consequences: New York bars employers from *requiring* fingerprinting[92], which favors face, palm vein or iris as the mandatory factor there.

Certify against bounded attackers, architect against injection

Presentation-attack detection (PAD) is evaluated under ISO/IEC 30107-3, most commonly through iBeta's two levels and FIDO's Biometric Component Certification. NIST sets the federal floor. Each regime tests something narrower than a frontier-lab threat model.

REGIME	WHAT IT TESTS	THRESHOLDS	WHAT IT DOES NOT COVER
NIST SP 800-63B-4[19]	Biometric use in federal authentication	Biometrics only with a physical authenticator; FMR ≤1:10,000 for every demographic group; PAD SHALL for face, SHOULD for iris and fingerprint; IAPAR SHOULD be below 0.07; sensor authenticated before capture for central comparison; voice prohibited	Continuous authentication; injection metrics
iBeta ISO/IEC 30107-3 Level 1 / Level 2[114, 115]	Presentation attacks by bounded attackers	Artefacts ≤$30 / ≤$300; 8 h / 24 h per attack species; 150 attacks and 50 genuine presentations per species; 0% (L1) and 1% (L2) penetration in iBeta's 2022 comparison	Injection; bespoke, well-funded artefacts
FIDO Biometric Component Certification v4.1[21]	Matcher accuracy and PAD at the capture device	Lab FAR 1:100 (BioLevel 1) and 1:10,000 (BioLevel 2) at the 80% confidence bound; IAPAR ≤15% (Level 1) and ≤7% (Level 2)	No numeric injection or replay threshold; vendor documents countermeasures only. v5.0 is in draft[116], and trade press reports injection requirements being added (secondary)[117]
CEN/TS 18099[22]	Injection-attack detection	Approved 13 Oct 2024 for provisional application, initially 3 years; ISO/IEC 25456 counterpart still a draft, expected around 2027[118, 117]	Presentation attacks and secure-element implementation are out of scope

The known-spoof record shows why "internal feature" and "3D" marketing claims need testing. Gelatin fingers molded from latent prints fooled 11 fingerprint devices in 2002[91]. A printed photo plus a contact lens beat the Galaxy S8 iris scanner in 2017[100]. Wax hands built from photos taken with a camera whose IR filter had been removed defeated Fujitsu and Hitachi vein sensors in 2018, after about 2,500 photos and 30 days of tuning[95]. Replayed ECG fooled the original Nymi band 81% of the time[103]. A printed IR photo fooled Windows Hello[89]. These attacks cost little. iBeta's cost caps of $30 and $300 are far below what an adversary targeting frontier-model weights would spend. Certification therefore shows resistance to bounded attackers only, and Vault's threat model should assume bespoke artefacts such as silicone masks and custom wax hands (inference).

Injection matters more than any mask because it bypasses PAD entirely. The countermeasure that works is architectural. Apple's Touch ID channel is encrypted and authenticated with a per-sensor key. Face ID randomizes its sequence of 2D and depth captures and projects a device-specific pattern, which acts as a built-in challenge-response against replayed depth data[23]. ESS lets only the face camera write into hypervisor-protected memory[12]. The weakness of both is coverage: ESS does not support external cameras[12], and CyberArk warned that any system accepting third-party USB cameras as biometric sensors may be affected by frame injection[55]. Hardware indicators are not a substitute: the 2013 "iSeeYou" research disabled the hardware-interlocked camera LED on older MacBooks by reflashing camera firmware[119]. The notes

therefore propose a procurement specification for Vault (inference). Every biometric sensor should carry iBeta Level 2 PAD or FIDO certification with IAPAR ≤7%. The false-match floor should be NIST's 1:10,000 per demographic group, set far lower in practice (for example 1e-6 for face), and the biometric should always be bound to a hardware authenticator. The camera should be integrated and firmware-locked, with frames signed to the secure element and an unpredictable illumination nonce, and USB and virtual cameras should be blocked by policy. Software injection-detection heuristics in the CEN/TS 18099 style then become defense in depth rather than the primary control.

Signal explicitly, degrade silently, make coercion unprofitable

Signals and the quality of their evidence

Duress signals fall into two families. **Explicit covert signals** let the victim choose to signal, so they carry no "stress versus duress" ambiguity. **Inferred signals** try to read coercion from physiology, behavior or the environment. Only the first family has a long deployment record, and only the environmental and task-level parts of the second are likely to be both useful and lawful.

SIGNAL FAMILY	EXAMPLES	BEST EVIDENCE	EVIDENCE QUALITY	VAULT ROLE (INFERENCE)
Explicit covert signal	Alarm-panel duress code that makes the panel appear disarmed[120]; duress finger that opens the door while alarming[121]; duress PIN that opens a decoy wallet[9] or wipes the phone[122]	Long deployment, but no field data on correct use under real fear. ATM emergency PINs were never deployed, and a Wells Fargo alarm-button pilot produced 500 false alarms and no real ones[8]	Field and documentation; no accuracy data	Primary and only "hard" trigger
Physiology (HR/HRV, EDA, temperature)	Chest and wrist wearables	WESAD: 93% binary and 80% three-class accuracy, 15 mostly young male subjects, chest strap[24]; field F1 fell from 0.84 to 0.71[25]; in a government in-the-wild program no team met its targets[26]; poor transfer to new datasets[123]	Lab only; no real-coercion data	None in the EU; at most a tie-breaker elsewhere
Voice stress, micro-expressions, behavior detection	VSA, METT, SPOT-style indicators	Voice stress analysis at chance, catching ~15% of liars[124]; layered voice analysis hit rates ~42–56%[125]; behavioral indicators "the same as or slightly better than chance" across 400+ studies[126]; micro-expression training no better than none[127]	Government and field reviews	Excluded
Behavioral biometrics under stress	Keystroke rhythm, mouse stiffness	Stress signal strong *within* a subject[128]; keystroke models need personalization[129]	Lab	Drift indicator only; expect stress to raise false rejects
Task-level anomaly	Bulk export, new egress destination, disabling audit, quorum changes	For rare events the false-alarm rate, not the detection rate, is the binding constraint[28]; no independent false-positive rates for commercial insider-threat analytics were found	Academic	Strong policy trigger, because the coercer's goal is anomalous by construction

SIGNAL FAMILY	EXAMPLES	BEST EVIDENCE	EVIDENCE QUALITY	VAULT ROLE (INFERENCE)
Environmental	Second face in frame, room occupancy	A face in view "does not always indicate an attack"[130]; only revolving doors and mantraps *prevent* tailgating[131]	Lab and patent	Friction trigger; blind to coercion at home
Coercion-resistant credentials	Implicitly learned sequences; physiology-bound keys	Bojinov: ~38-bit sequence, 30–45 min training, 5–6 min to authenticate[52]; voice plus skin-conductance keys with "moderate" error rates on 39 subjects[132]	Lab	Not for v0

The deception-detection literature is the closest analog to "read a hidden mental state from physiology," and it is sobering. The National Academies found polygraph screening "an unacceptable choice" for employee security screening, and noted that no alternative such as facial expression, voice or brain activity "has yet been shown to outperform the polygraph"[27]. Physiology is also non-specific. Skin conductance tracks heat, dehydration and exertion as well as stress[133], and operators will be legitimately stressed exactly when Vault matters most: incident response, release deadlines, 3 a.m. pages.

Base rates sink inferred duress

The National Academies' polygraph example frames the arithmetic. In 10,000 employees containing 10 spies, a threshold that catches about 8 spies flags about 1,598 innocent people, and a threshold tuned to limit false alarms catches only 2[27]. Axelsson's analysis of intrusion detection makes the same point: for rare events, the false-alarm rate, not the detection rate, decides whether alerts are useful[28]. The notes work a Vault-specific illustration (their own arithmetic, not from a source). Fifty operators opening four sessions a day produce about 73,000 sessions a year. If genuine duress happens once a decade, a detector with 95% sensitivity and a 1% false-positive rate raises about 730 false alarms a year, and even 0.1% yields about 73. An inferred-stress detector therefore cannot drive alarms or police dispatch. At most it can add minutes of friction.

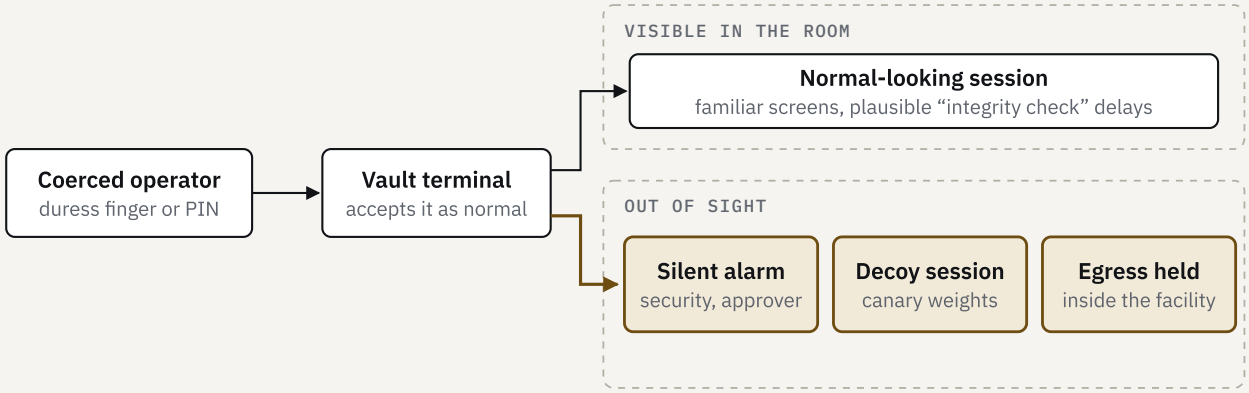
Response design: what pharmacies, vault locks and hardware wallets already know

The strongest lesson from ATMs, pharmacies, cash-in-transit, bank time locks and crypto self-custody is to **make coercion unprofitable rather than detect it perfectly**. Two-person control is the most battle-tested form. The US Air Force's nuclear two-person concept ensures "a lone individual cannot perform an incorrect act or unauthorized procedure" and designates no-lone zones[30]. Time delays are the second form. Electronic vault locks pair a 1–99 minute delay with a silent duress module (vendor)[134]. Police reported an 82% drop in Toronto pharmacy robberies in 2024 after time-delay safes[135]. Mandatory standards in British Columbia were reported to have cut pharmacy robberies 94%, and a Calgary detective states that time-delay safes "do not lead to an escalation of violence"[136]. These are uncontrolled before-and-after comparisons, and the "no escalation" claim is a police assertion, not a study. Removing the payoff is the third form. Belgium mandates banknote-staining systems for cash in transit[137], and Bitcoin covenant "vaults" add a delay window in which a recovery key can claw back a theft[138].

The second lesson is that **the response must be invisible**. The FTC's review quotes Illinois regulators saying the risk of harm "is greatly increased should they resist". It notes that visible alarms may raise the danger, and that only 26.4% of police responses to reported robberies arrive within five minutes[8]. Clark and Hengartner's analysis of panic passwords

sets the formal requirement. The duress credential must be "indistinguishable" by the attacker, and any lockout must be "invariant to the type of the passwords being entered". A visible lockout invites "threatening retaliation". Attackers who can watch, iterate or force random choices among the victim's passwords will screen out inconsistent fake responses[29]. Coercion-resistant voting reaches the same answer with fake credentials indistinguishable from real ones[139]. Decoys must also be internally consistent: Windows, Word and Google Desktop each leaked evidence of a TrueCrypt hidden volume[140]. Coldcard's duress PIN shows the product form, a functioning decoy wallet where "nothing special is shown on the screen"[9]. GrapheneOS's irreversible duress wipe[122] is the wrong default for an operator held by an attacker who expects success.

The notes turn these lessons into a proposed response policy for Vault (proposal):



Signal explicitly, degrade silently (proposal). An explicit duress signal never produces a visible lockout or wipe, because those can get a coerced person hurt. The session looks normal while security and the remote approver are alerted, a decoy environment with watermarked non-production weights takes over, and all egress is quarantined inside the facility. A watching attacker can't tell that the signal was given[29, 9, 8].

TRIGGER	RESPONSE, INVISIBLE TO THE ATTACKER	GROUNDING
Any irreversible weights action, always	Quorum of live, verified people plus a time delay, whatever the signals say; publicized so that "I can't" is credible	Two-person control[30]; pharmacy time delays[136]; Lopp's "should be intentionally difficult" (secondary)[48]
Explicit duress signal (duress finger or PIN, usable at any point in the session)	Session looks normal; silent alarm to security and the remote approver; decoy or canary environment (watermarked non-production weights, honeytoken credentials); all egress routed to an in-facility quarantine; plausible delays ("integrity verification")	Indistinguishability[29, 139]; decoy wallet[9]; honeywords[141]
Two independent non-emotion channels agree (for example an unexpected second face plus an out-of-scope export)	Friction ladder: longer delay, then remote re-confirmation, then a two-person requirement; scope shrinks toward read-only and sandbox rather than a hard lock	Base rates[28]; environmental limits[130]
Single inferred channel	Log it and raise the trust threshold for privileged actions	Base rates[27]

TRIGGER	RESPONSE, INVISIBLE TO THE ATTACKER	GROUNDING
Physiological stress inference	Off in the EU; elsewhere at most a tie-breaker that adds friction	AI Act Art. 5(1)(f)[10]; accuracy evidence[25, 26]

Three supporting practices complete the design (proposal). Remote approvers need their own out-of-band duress channel and should be trained to *appear* to approve while escalating. When duress is suspected, someone should check on the operator's home and family, because coercion often happens there; that is the lesson of tiger kidnappings, where protocols put hostages' safe return first[49]. Duress actions must be rehearsed, simple and forgiving, because the FTC's concern that victims "fumble" emergency PINs is real[8]. Any "off switch" a coerced user can operate, such as 1Password's Travel Mode, which removes non-travel vaults and their keys from the device, is itself a coercion target[142]. Restoring full access should therefore need something the operator alone cannot do. Publicity may deter on its own. In one study, arrestees told they were being monitored by voice stress analysis lied less, even though the tool performed at chance[124].

Heirs are a key ceremony, not a biometric

Personal lineage: what shipping inheritance products actually do

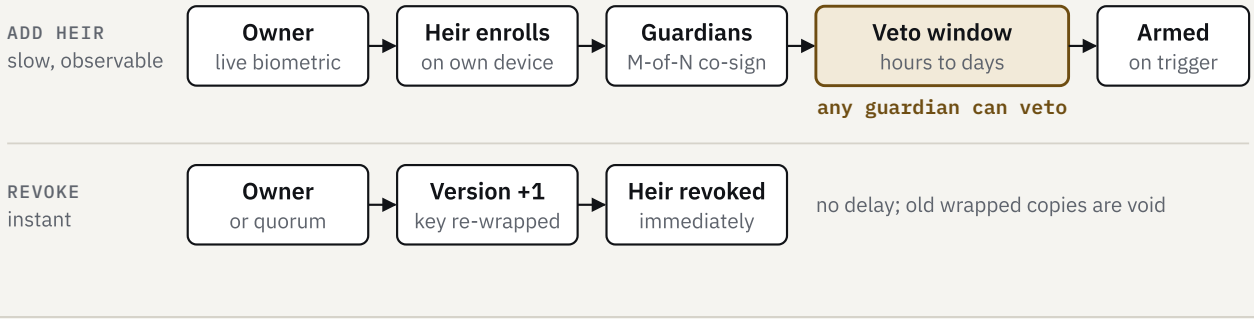
The products that pass control of high-value secrets to heirs fall into three patterns. Some split shares across trustees. Some use multisig, where the heir holds a dormant key and a custodian co-signs after a legal or time-delayed process. Others use social recovery, where guardians rotate the signing key after a delay the owner can veto. All of them pair cryptography with a waiting period and a human or legal attestation, and none relies on cryptography alone.

PATTERN	EXAMPLE	MECHANISM	WAITING PERIOD / VETO	LESSON FOR VAULT (INFERENCE)
Two-level threshold sharing	SLIP-39[143]	Group shares GT-of-G, member shares Ti-of-Ni, at most 16 groups of 16; passphrases cannot be verified, so a wrong one opens a different valid wallet	None built in	Model institutional custodian groups; decoy passphrase as a duress idea
Custodial shard escrow	Ledger Recover[144]	Seed split 2-of-3 across HSMs at Ledger, Coincover and EscrowTech; recovery needs ID document plus selfie video verified by two providers	Process-based	Avoid tying recovery to a third-party identity database
Multisig plus custodian plus legal gate	Casa[34]; Unchained[145]	Heir holds an encrypted or dormant key; custodian co-signs after an inheritance request (Casa) or legal documents (Unchained, third-party description)	Casa: 6 months, living owner can cancel	Dormant heir credential plus a long veto window
Social recovery	Vitalik Buterin's design[35]; Argent[146]	Guardians can replace a lost signing key; the signing key can change guardians only after ~1–3 days; 7+ guardians from different circles	Argent: 36 h (secondary)	Make additions slow and observable
Inactivity / dead-man switch	Google Inactive Account Manager[147]; Liana[148]	Inactivity timer; in Liana the owner "refreshes" coins to keep the heir's relative timelock closed[149]	Google: configurable inactivity period, up to 10 recipients	Owner liveness keeps the heir path shut
Pre-shared key plus proof of death	Apple Legacy Contact[150]	Access key plus death certificate; any one Legacy Contact can act alone; Keychain excluded	Human process	Use a threshold, not a single holder
Request plus grantor-set wait	Bitwarden emergency access[36, 151]	Grantor's key encrypted to the contact's RSA public key; View or Takeover mode	Minimum 1 day; auto-approves if the grantor is silent	Wrap the succession key to each heir's public key in advance

Coercion resistance in these systems comes from **asymmetric delays**: sensitive changes are slow and observable, while cancellation is fast. Apple's Stolen Device Protection requires biometric authentication, then a one-hour security delay, then biometric authentication again before a recovery contact or enrolled face can be changed away from familiar locations[59]. The withdrawn Bitcoin OP_VAULT proposal paired a hot trigger key with a cold recovery key that can claw funds back during a withdrawal delay, explicitly as a defense against coerced spends[152].

A proposed heir protocol for Vault

No standard exists for "biometric heirs," and this research found no product that binds owner-authorized biometric heirs to hardware. The following design is the notes' proposal, extrapolated from the patterns above. **Designation** should be an owner-signed delegation, generated and signed inside the owner's secure element, binding the heir's device-bound public key to a policy covering activation conditions, scope and expiry. The heir's template should be enrolled on the heir's own Vault and never exported. The owner's device holds only the heir's public key and policy, which keeps the design inside the on-device storage model that EU regulators favor[31, 153]. **Adding an heir** should be the most dangerous operation in the system. It should require live owner biometrics with liveness, live heir enrollment on the heir's own hardware, M-of-N guardian co-signatures, and a security delay of hours to days during which every guardian is notified and any one can veto. It should be allowed only in an enrolled secure facility. **Revocation** is the mirror image: instant for the owner, or quorum-only when the owner is unavailable. A monotonic policy-version counter in the secure element, plus re-wrapping of the succession key on every change, makes old wrapped copies useless. With this asymmetry, a coerced owner can be forced to *start* an addition but cannot *complete* it before others can intervene. **Activation** borrows Liana's model: every live owner session resets an inactivity counter, and the heir path becomes armable only after N days without owner presence *and* trustee attestation of death, incapacity or departure. A **duress signal** during "add heir" should make the ceremony appear to succeed while silently freezing it and alerting guardians, echoing SLIP-39's unverifiable decoy passphrase[143].



Asymmetric delays (proposal). Adding an heir is the most dangerous operation in the system, so it is slow and observable: live owner, live heir on the heir's own hardware, a guardian quorum, then a veto window. Revoking is instant. A coerced owner can start an addition but can't complete it before guardians can step in. A duress signal during the ceremony makes it appear to succeed while silently freezing it[59, 35, 143].

Device-only templates create one tension, which the notes flag. If a Vault is destroyed, the biometric cannot be restored from backup, so recovery must come from the cryptographic layer through re-enrollment authorized by quorum, never from template copies. This matches Apple's "never backed up" stance[153]. A second tension is this report's inference: RAND's SL5 list includes an "irrecoverable key policy"[1]. Vault should therefore support a mode with succession disabled for the highest tiers, in which recovery means re-keying the weights under a fresh quorum rather than inheriting access.

Why kinship and DNA fail as a gate

A "kinship heir" gate fails on every axis. It is slow: FBI-approved Rapid DNA booking systems take about 90 minutes (vendor release)[37]. It is not secret: in a 2024 University of New Hampshire study, one person's DNA transferred to a second person's hand in 50% of trials[38]. It is probabilistic for relatives: even at 40 STR loci, half-siblings showed 5–7% false inclusion or exclusion[39]. It is legally toxic: GINA bars US employers with 15 or more employees from requesting genetic information about an employee *or an employee's family member*[40], and genetic data is special-category data under GDPR Art. 9[154]. Succession must rest on explicit owner authorization, not biology.

Enterprise succession: successor operators and break-glass

In an AI lab, an heir is a **successor operator**, and the mature playbook already exists. It consists of M-of-N quorum on HSM administration, sealed break-glass credentials with alert-on-use, two-party authorization for weight access, and joiner–mover–leaver processes. Vault's contribution would be making each custodian's approval biometric-bound and non-delegable. A smartcard can be lent; a live face match on a dedicated terminal cannot (inference).

PERSONAL CONCEPT	ENTERPRISE EQUIVALENT	EXISTING PRECEDENT
Owner	Primary operator with no standing access	Anthropic: "no person has persistent access to production-critical environments"[155]
Heir	Pre-approved successor operator	IANA Root KSK Ceremony 13 replaced a Crypto Officer[156]
Guardians	M-of-N custodians (security, legal, executive sponsor)	DNSSEC root KSK: 3 of 7 Crypto Officers per facility, 5 of 7 recovery share holders (2010 design)[157]; AWS CloudHSM quorum of 2–8 approvers, tokens expire after 10 minutes[41]
Dead-man switch	Leaver trigger plus custodian attestation	NIST SP 800-53 PS-4 and PS-5 revoke access on termination and review it on transfer (secondary summary)[158]
Paper recovery kit	Sealed, non-biometric break-glass	Microsoft Entra: at least two emergency accounts with phishing-resistant authentication, credentials in separate fireproof safes, alert on every sign-in, validation at least every 90 days[42]

Microsoft's guidance explicitly lists the scenario in which "the person with the most recent Global Administrator access leaves the organization"[42]. That is why Vault needs a **non-biometric break-glass path**: sealed, quorum-held and alarmed. A biometric-only system has no recovery if every enrolled operator is unavailable, and auditors will expect one (inference).

Verification is defensible, emotion inference is not

EU AI Act Art. 5(1)(f) and what it does to duress design

Art. 5(1)(f) prohibits placing on the market, putting into service or using AI systems "to infer emotions of a natural person in the areas of workplace and education institutions, except where the use … is intended … for medical or safety reasons"[159]. The prohibitions have applied since 2 February 2025, and the 2026 AI Omnibus did not delay them[159, 160]. The Commission's guidelines (C(2025) 5052 final, July 2025) are non-binding; only the Court of Justice can give an authoritative interpretation. They nonetheless set the regulatory reading, and that reading is wide[10]. The ban binds both providers and deployers (para 243). "Emotion recognition" covers inferring "emotions or intentions", the Recital 18 list is "not exhaustive", and the ban "should not be circumvented by referring to attitudes" (paras 244, 247–248). On stress the guidelines are explicit. "The general monitoring of stress levels at the workplace is not permitted under health or safety aspects", and an employer "would be prohibited from deploying AI-enabled devices … for measuring anxiety based on measured stress levels" unless elevated stress "would pose a specific danger", such as around dangerous machines or chemicals (paras 257, 263). In-scope biometric signals include keystrokes, heartbeats, ECG and EEG, and inferences from "key stroke …, facial expressions, body postures or movements" (para 251). "Workplace" includes contractors, trainees and candidates (para 254).

The safety exception is narrow. It applies "only in relation to the protection of life and health and not to protect other interests, for example property against theft or fraud" (para 258). Use under it must be "strictly necessary and proportionate", backed by a "prior written and motivated expert opinion", limited in time and scale, and barred from secondary use (paras 259–260). Workers must be consulted, the guidelines add that such systems "will require also consent", and Member States may ban workplace emotion recognition outright (para 264, footnote 167)[10]. Law-firm commentary reads the exception as excluding routine monitoring "reframed as safety"[161]. The consequence for Vault is direct. Duress inference justified as protecting model weights protects property, so the exception very likely does not apply. Duress inference framed as protecting the operator's life is arguable but untested, and a regulator would look at the marketed purpose (inference).

DURESS DESIGN ELEMENT	LIKELY STATUS IN THE EU WORKPLACE (INFERENCE UNLESS NOTED)	BASIS[10]
Explicit duress PIN, finger or gesture	Outside the ban: nothing is inferred	Definition requires inferring emotions or intentions from biometric data
Task-level anomaly (bulk export, new egress)	Outside: not derived from biometric data	Emotion inferred from written text is out of scope (para 251)
Second face, a hand on the operator, absence, liveness failure	Likely outside if not used to infer emotions	Readily apparent expressions and gestures are excluded unless used to infer emotions (paras 249, 261, 265)
Incapacitation or fatigue	Likely outside, by analogy	Physical states such as pain or fatigue are not emotions (para 249)

DURESS DESIGN ELEMENT	LIKELY STATUS IN THE EU WORKPLACE (INFERENCE UNLESS NOTED)	BASIS[10]
HR/EDA stress, voice stress, micro-expressions, keystroke stress	Presumptively prohibited	"Measuring anxiety based on measured stress levels" is the guidelines' own prohibited example (para 257); safety means life and health, not property (para 258)
Emotion recognition used lawfully outside the ban	High-risk from 2 Dec 2027, plus Art. 50(3) transparency duties	Annex III(1)(c)[162]; Omnibus timeline[160]

Verification sits outside the AI Act's riskiest categories

Vault's identity function is low-risk under the AI Act; its duress function is where the hazard lies. Biometric verification against a template "stored on a device" is outside the remote-biometric-identification ban. Confirming identity "for the sole purpose of … unlocking a device, or having security access to premises" is excluded from "remote" (guidelines paras 303–305)[10], and Annex III(1)(a) excludes sole-purpose verification from high-risk identification[162]. One uncertainty remains: no guidance addresses *continuous, passive* re-verification, which involves less active participation than a one-time unlock (inference). The 2026 AI Omnibus moved Annex III high-risk obligations to 2 December 2027[160]. Whether the national-security exclusion in Art. 2(3) could cover a lab's classified work was not researched.

GDPR: necessity, on-device templates and a pending exception

Biometric data processed to uniquely identify someone is special-category data under GDPR Art. 9. Member States may add conditions, and high-risk processing needs a DPIA under Art. 35[154]. Employee consent is presumptively invalid because of the power imbalance[163]. Employers therefore need a national legal basis and demonstrated necessity. The Netherlands' implementing act permits biometrics "necessary for authentication or security purposes", and its explanatory memorandum contrasts a nuclear power plant (likely justified) with a car garage (unlikely)[164]. The Dutch regulator fined a company €725,000 in 2020 for fingerprint time clocks[165], and Belgium fined an employer €45,000 in 2024 for consent-based fingerprint time tracking[166]. France's CNIL limits workplace biometrics to access control to premises, devices and applications, rejects them where a badge would do, prefers templates under the person's exclusive control ("Type 1"), and makes a DPIA mandatory[32]. The EDPB's Opinion 11/2024 found templates held on the individual's own device "in principle compatible" with GDPR, and centralized operator-controlled templates "cannot be compatible" with Art. 25[31]. A Commission proposal would add an Art. 9(2)(l) exception for verification where the biometric data and means "remain under the data subject's sole control". The EDPB and EDPS welcomed it in Joint Opinion 2/2026, but it was still a proposal at last check[167]. Every enforcement case found involved time and attendance, so Vault should never be positioned or configured as an attendance or productivity tool (inference). A lab protecting model weights sits near the nuclear-plant end of the Dutch test, but *continuous* monitoring needs its own necessity case. The defensible configuration verifies at session start and at sensitive actions, with continuous checks running as on-device presence that keeps no stored history (inference).

United States: a patchwork that mostly favors security access

The US has no general ban on workplace emotion recognition. Exposure comes from biometric-privacy statutes, notice laws and a few modality-specific rules.

JURISDICTION	RULE	EFFECT ON VAULT (INFERENCE)
Illinois (BIPA)	Written release, retention policy, $1,000 per negligent and $5,000 per intentional or reckless violation, private right of action[168, 169]; 2024 amendment makes repeated collection one violation[170], held retroactive in *Clay v. Union Pacific* (7th Cir., 1 Apr 2026)[171]	E-signed release and public retention policy at onboarding; a 1,000-operator site still carries roughly $1M–$5M theoretical exposure for a paperwork lapse
Illinois case law	Facebook $650M settlement[172]; BNSF truck-driver case $228M verdict vacated, settled for $75M[173]; *Barnett v. Apple* dismissed claims over biometrics stored only on-device[33]	On-device storage helps the vendor; an employer that requires enrollment is plausibly still the "collector"
Texas (CUBI)	Attorney-general enforcement up to $25,000 per violation; Meta $1.4B and Google $1.375B settlements[174]	Consent and retention discipline
Colorado (HB24-1130, from 1 Jul 2025)	Employers may require biometric consent to "permit access to secure physical locations and secure electronic hardware and software applications", but not for tracking time spent on an application[175]	Supports the core use; keep presence logs from becoming activity tracking
Washington	No notice or consent needed for biometrics collected "in furtherance of a security purpose"[176]	Supports the core use
New York	Employers may not require fingerprinting (Labor Law §201-a)[92]; bill S681 would extend this to iris and retina[177]; electronic-monitoring notice required (Civil Rights Law §52-c)[178]	Avoid mandatory fingerprint; disclose monitoring
California (CCPA/CPRA)	Workforce data fully in scope since 2023; risk assessments for sensitive personal information from 1 Jan 2026[179]	Risk assessment before rollout
Federal (GINA)	No requesting genetic information about employees or their families[40]	Rules out DNA or kinship gates

Ethics: power, function creep and the operator's safety

Three ethical risks deserve design attention. The first is **power**. Workplace-law commentators argue that even when employers cannot read templates, the imbalance that makes employee consent invalid remains, and that on-device exceptions could legitimize systematic employer biometrics[180]. **Function creep** is the second. A continuous presence log is personal data and can become productivity surveillance, which Colorado expressly resists[175], so logs should be minimal, local and limited to security events (inference). The third is **the operator's physical safety**, which should be an explicit design objective. Visible lockouts and wipes can get a coerced person hurt[8, 29], and a published policy that no single person can release weights quickly protects operators the way "staff cannot open this safe" signage protects pharmacists (inference). Frontier-AI laws push labs toward *more* insider monitoring, while the AI Act and GDPR push against biometric *inference* about employees. The notes conclude (inference) that the two meet in one design: verification, explicit duress signals and multi-party approval, without affect inference.

A dozen buyers, rising mandates and an empty intersection

Buyers and who owns the problem

The core buyer set is very small. Epoch AI counted more than 30 publicly announced models above 10^25 FLOP from 12 developers as of June 2025[181], and CAISI's pre-deployment testing agreements covered five frontier labs in May 2026[182]. The notes estimate (inference) about 5–12 tier-one frontier developers. Around them sits a second ring of hyperscalers, neoclouds and inference providers holding partner weights, and a third ring of government AI and intelligence data centers, which the 2025 US AI Action Plan prioritizes[183] — fewer than 100 organizations in 2026 by the notes' rough count. Ownership sits with the CISO and security engineering. Anthropic's CISO was quoted in 2023 saying he spends "almost half of my time" protecting "that one file", as cited in House testimony[184]. Sales will be few, large and high-touch.

Compliance hooks create demand but do not mandate biometrics

Weight-security obligations now exist in law and quasi-law. California's SB 53 requires large frontier developers to publish frameworks describing "cybersecurity practices to secure unreleased model weights from unauthorized modification or transfer by internal or external parties". It treats weight exfiltration as a critical safety incident, with civil penalties up to $1M per violation (law-firm summary)[185]. New York's amended RAISE Act takes effect on 1 January 2027[186]. Appendix 4 of the EU GPAI Code of Practice (as reproduced by an unofficial mirror of the final text) calls for "restrictions on device and account sharing", MFA, zero trust, authorization reviews "at least every six months", limits on "the number of people with non-hardened interface-access", background checks and "periodic personnel integrity testing"[187]. RAND's August 2026 SL3 follow-up proposes 262 controls adapted from NIST SP 800-53 (search listing; full text not read)[188]. OpenAI aligns its security controls with ISO 27001, SOC 2, NIST SP 800-53 and FedRAMP[3]. None of these mandates biometrics. Buyers will compare Vault with FIDO2 keys plus two-person rules, so Vault's marginal value must be **non-delegability** (cards can be lent, faces cannot) and **presence continuity** (inference).

Lab frameworks leave the human unverified

Anthropic's ASL-3 protections (May 2025) include "more than 100 different security controls", "two-party authorization for model weight access" and egress bandwidth controls, but place sophisticated insider risk "out of the scope"[2]. Its RSP v3.0 points to security "roughly in line with RAND SL4" in industry-wide recommendations for higher capability thresholds, and describes "moonshot R&D for security" projects[44]. OpenAI's Preparedness Framework v2 requires "hardware-backed security", strong MFA, managed devices and "multi-person approval" for critical infrastructure changes[3]. Secondary coverage reports that OpenAI paused work on a model in August 2026 and is rewriting its framework after an evaluation-related breach; OpenAI's own posts were not retrieved[189]. Also per secondary coverage, Google DeepMind's FSF v3.1 adds "ID verification for staff with sensitive access"[190], and Meta limits protections to what is "technically feasible and commercially available"[191]. The Frontier Model Forum recommends phishing-resistant MFA, no "static or persistent credentials" and quorum operations[11]. The notes infer that Anthropic is the most likely early design partner, given its insider exclusion and its "moonshot R&D" language. They see Google DeepMind's ID-verification language as a second hook, OpenAI's rewrite as a time-bounded window, and Meta's "commercially available" caveat as a signal that Meta would buy rather than build.

Competitors and the gap no product fills

PRODUCT	LAYER	WHAT IT DOES	WHAT IT LACKS FOR VAULT
Teleport[192, 75]	Infrastructure access	Per-session MFA; non-exportable hardware keys with touch cached for 15 s; dual authorization; moderated sessions	Binds to keys and devices, not a continuously verified human
CyberArk / Palo Alto Networks[193, 194]	PAM leader	ARR $1.44B (FY2025); acquired by Palo Alto for about $25B	No continuous biometric binding found; has distribution to bolt it on
Okta Identity Threat Protection[195]	Session risk	Continuous re-evaluation of session risk; terminate or step up	Software signals; no hardware-attested human
Plurilock[196]	Behavioral biometrics	Keystroke and mouse checks "every 3–5 seconds" (vendor claim)	Weak, software-only modality
SecureAuth SessionGuardian; OLOID[64, 65]	Continuous face / presence	Periodic face checks; lock on absence (vendor)	No published liveness, injection defense or independent evaluation
Nymi Band[197, 101]	Wearable biometric	Fingerprint on band, FIDO2, on-body custody; "nine of the top ten" pharma companies (vendor claim)	Custody, not presence at the keyboard; ECG replay attack[103]
HYPR + YubiKey Bio[198]	Biometric authenticator	Fingerprint FIDO plus PIV key, generally available since Nov 2024	Point-in-time touch
Fortanix Confidential AI[74]	Weights protection	Weights released only after composite CPU+GPU attestation; key in an HSM (vendor claim)	No human attestation; likely partner, not competitor
Duress detection	Patents only	Biometric verification with duress detection; coercion scoring that returns decoy data[199, 200]	No shipping enterprise product found

CAPABILITY VAULT NEEDS	CLOSEST EXISTING OFFERING	STATUS
Biometric binding at every privileged action	YubiKey Bio, Teleport hardware keys	Partial: binding at touch time only
Hardware-attested continuity	Plurilock, Okta ITP, SecureAuth	Missing: software-only, on general endpoints
Verified co-presence (two humans at the terminal)	Teleport moderated sessions	Missing: remote moderators, not verified co-present humans
Duress signaling with decoy or quarantine	Patents; consumer wallets	Missing in enterprise PAM
Coupling to weight-egress controls	Confidential computing, bandwidth limits	Missing at the terminal: server side only

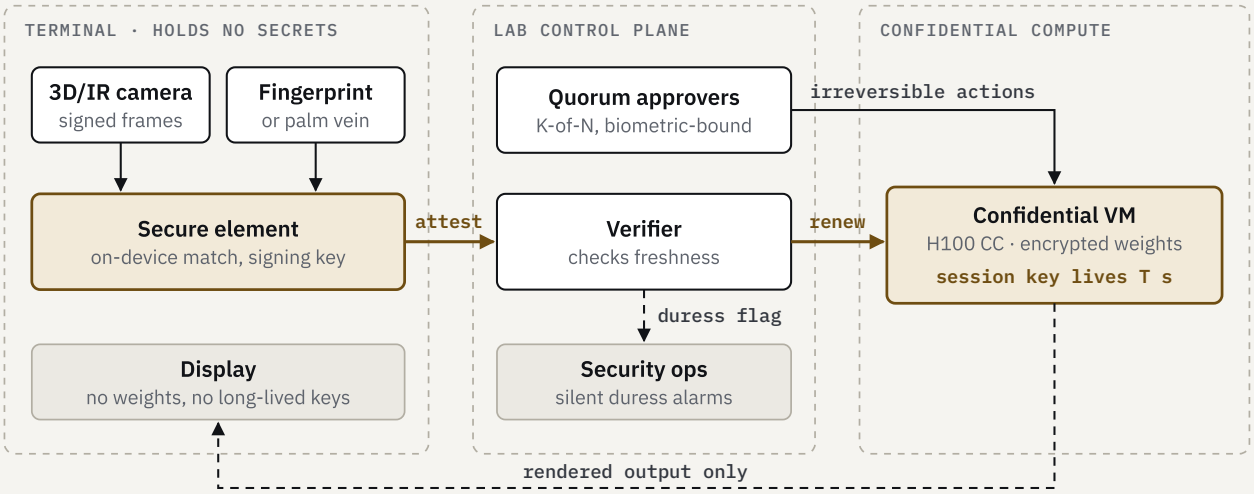
Market size and go-to-market

Generic privileged access management is sizeable but not Vault's market. Third-party estimates for 2025 range from about $2.5B to $4.5B, with growth rates of 15–24%, and the estimates disagree widely[201, 202]. Vault's niche is a wedge. The closest comparable is Irregular (formerly Pattern Labs), which raised $80M in September 2025 led by Sequoia and Redpoint, selling security work to a handful of frontier labs; its co-founder co-authored the RAND weights report[203]. The notes propose this path (inference). Start with a design partnership with one lab's security engineering team. Map Vault to RAND SL3/SL4 controls, EU Appendix 4 and SB 53 framework language. Obtain SOC 2 Type II and ISO 27001, and later FedRAMP or CMMC for government and data-center buyers. Pass a physical red-team validation. The biggest competitive threats are Teleport, Palo Alto/CyberArk and labs' in-house teams. Confidential-computing vendors are natural partners, with Vault deciding *who* may trigger key release and the vendor deciding *where* it happens. The nonprofit Security Level 5 convenes labs, data-center operators and chip providers, which is a natural standards venue[204].

v0 reference architecture, open questions and Phase 2 scope

Reference architecture (proposal)

The v0 design below assembles the evidence into one system. Every row is a proposal built from the cited findings, not a validated product.



Proposed v0 reference architecture. The terminal holds no weights and no long-lived keys. Its secure element matches the operator on-device and signs a presence attestation every few seconds. A lab-controlled verifier renews a seconds-scale session key inside the confidential VM only while those attestations stay fresh; when they lapse, the key is dropped. Irreversible actions also need a biometric-bound quorum and a delay. Duress flags go silently to security operations, and only rendered output returns to the terminal[13, 6, 23].

LAYER	V0 CHOICE	WHY
Terminal	Dedicated, secretless thin client: no weights, no long-lived secrets, display only; tamper-evident chassis; attestation key in a FIPS 140-3 Level 3 element that zeroizes on intrusion, which revokes the terminal server-side	Level 3 adds tamper detection and response that zeroizes secrets[88]; FIPS 140-2 certificates moved to the historical list in Sept 2026[205]
Capture and match	On-device matching in the secure element; sensors cryptographically paired; integrated 3D/IR camera with signed frames and randomized illumination; USB and virtual cameras blocked	Paired-sensor model[23, 12]; injection evidence[55, 20]

LAYER	V0 CHOICE	WHY
Session open	Explicit strong biometric (fingerprint, palm vein or iris) signing with a non-exportable secure-element key, plus a FIDO hardware authenticator	NIST: biometrics only with a physical authenticator[19]
Presence stream	Secure-element-signed attestations every few seconds containing the match result, measured boot state and epoch; epoch-ID freshness plus a maximum-staleness bound	RATS roles and freshness; "freeze time" risk[13]
Relying party	Confidential VM (H100/Blackwell CC on TDX or SEV-SNP) or weights keyserver holding a seconds-scale session key renewed only on fresh attestation; lapse drops the key	Watchdog pattern[13]; attestation-gated key release[6]; composite CPU+GPU appraisal[57]
Trust and absence	Decaying trust score; face mismatch kills the session; absence locks within seconds; short grace window only with an unbroken custody link	DARPA usability target[17]; occlusion-driven false rejects[90]
Quorum and delay	K-of-N biometric-bound approvals plus a time delay for bulk export, new egress, and policy, quorum or heir changes; optional verified co-presence for SL5-style supervision	RAND SL3/SL5 benchmarks[1]; two-person control[30]
Duress	Duress finger or PIN usable at any time; silent alarm; decoy environment; quarantined egress; non-emotion environmental and task signals add friction; physiology off	Section 6 evidence; Art. 5(1)(f)[10]
Succession and break-glass	Owner-signed delegations to heirs' device-bound keys; guardians; asymmetric add/revoke with veto windows; sealed non-biometric break-glass; optional "irrecoverable" mode	Section 7 patterns[34, 59, 42]
Privacy and logs	Templates only on the operator's own secure element; tamper-evident security-event log with no continuous presence history; DPIA, BIPA release and Colorado-style policy shipped with onboarding	EDPB Scenario 1[31]; CNIL Type 1[32]; Colorado[175]

Platform choice and the continuity compromise

The hardest v0 decision is where continuous matching runs. Apple-silicon Macs with a paired Touch ID peripheral and Secure Enclave keys are the most mature commodity option for per-operation biometric-gated signing[23, 5]. On Windows, ESS fingerprint beats ESS face for a desk terminal because ESS face does not support external cameras[12]. Neither platform exposes continuous secure-element face re-verification, and secure camera paths on Linux, the likely environment of lab infrastructure, were not found in this research. The notes therefore imply an honest v0 compromise (inference). "Continuous" in v0 means a hardware-gated biometric signature on every privileged action, which satisfies RAND's "every interaction or ~60 seconds" benchmark[1], plus passive attested face presence that can only *lower* trust. True secure-element-continuous face matching is a Phase 2 question that may require a custom sensor-plus-secure-element module.

Open questions

OPEN QUESTION	WHY IT MATTERS	HOW TO RESOLVE
Can continuous face matching run inside a secure element on commodity hardware, or is a custom module required?	Determines whether continuity is hardware-rooted or merely telemetry	Phase 2 hardware spike; vendor discussions
Is there a secure camera path on Linux workstations?	Lab infrastructure is likely Linux-heavy	Driver and IOMMU investigation
Do newer NVIDIA attestation services bind GPU reports to a specific CVM after TEE.fail?	Prevents "borrowed" GPU attestations[57]	Vendor engagement; composite-appraisal testing
What false-lock rate do real operators experience over 40-hour weeks?	Usability decides adoption; no published grace-period data exist	Pilot against the DARPA target[17]
Does the AI Act's verification carve-out cover continuous passive re-verification?	Unaddressed in guidance	Regulatory counsel; DPA consultation
Is an employer the BIPA "collector" for on-device-only templates?	No case on point[33]	Counsel; conservative compliance by default
How many people hold weight access at each lab, and what controls do they use today?	Sizes deployments; no lab discloses it	Design-partner discovery
Does RAND's SL3 follow-up add biometric, multiparty or duress controls?	Full text not read[188]	Read RR-A4704-1
What are FIDO v5.0's thresholds and injection requirements?	Certification target[116]	Track the draft
Do real people perform duress signals correctly under fear?	No field data exist[8]	Rehearsal studies; red-team exercises
How does RAND SL5's "irrecoverable key policy" interact with succession?	Possible conflict with heirs[1]	Policy modes per tier
What do FIPS 140-3 validation cost and time look like for a custom element?	Budget and schedule; no data found	CMVP lab quotes

Proposed Phase 2 prototype scope

The Phase 2 prototype should prove the hybrid end to end against mock weights, with acceptance criteria drawn from the evidence. The targets below are proposals, not established benchmarks.

WORKSTREAM	BUILD	PROPOSED ACCEPTANCE CRITERION
Presence-attested session	Terminal prototype streaming signed attestations to a confidential H100 VM on Azure or GCP holding encrypted mock weights	No plaintext weights or long-lived secrets on the terminal; session key dropped within seconds of an attestation lapse

WORKSTREAM	BUILD	PROPOSED ACCEPTANCE CRITERION
Continuous-verification usability	Operator pilot over full working weeks	No more than 5 consecutive false rejects per 40 h[17]; impostor swap ends the session on the first mismatched match
Injection and PAD red team	Virtual-camera, USB-emulation and replay attacks; iBeta Level 2-class artefacts plus bespoke masks and wax hands	No injected frame accepted on the attested path; measured IAPAR ≤7%[21]
Quorum and delay	K-of-N biometric-bound approvals; export delay	No single operator completes a bulk export; card-lending is impossible by construction
Duress	Duress finger and PIN; decoy environment; quarantined egress	A red team iterating across sessions cannot distinguish duress from normal sessions[29]; alarms arrive silently
Succession and break-glass	Add-heir and revoke ceremonies; break-glass drill	A coerced owner can start but not complete an heir addition within the veto window; revocation is instant
Compliance pack	DPIA template, BIPA e-release, Colorado-style policy, EU switch that disables all inference features; mapping to RAND SL3, EU Appendix 4 and SB 53	Reviewed by counsel and the design partner's security team

Out of scope for Phase 2: physiological or voice duress inference, DNA or kinship gates, keys derived from biometrics, unsupervised home use, and SL5 facility controls.

The evidence changes what "biometric access control" should mean for frontier AI. The hard part is not recognizing a face; on cooperative images, leading matchers already operate well inside NIST's requirements. The hard part is turning recognition into a short-lived cryptographic fact that the system holding the weights can rely on, and arranging people, delays and decoys so that a recognized but coerced operator cannot deliver what an attacker wants. That reframing also resolves the apparent conflict between frontier-AI security mandates and EU worker protection: a Vault that verifies identity, accepts explicit signals and requires quorum meets both, while one that infers emotions satisfies neither the statistics nor the law.

Sources

1. Nevo et al., "Securing AI Model Weights: Preventing Theft and Misuse of Frontier Models" (RAND RR-A2849-1, 2024). *Think-tank report; PDF mirror of the RAND publication (landing page: https://www.rand.org/pubs/research_reports/RRA2849-1.html).*
2. Anthropic, "Activating AI Safety Level 3 Protections" (May 2025). *Lab primary source.*
3. OpenAI, Preparedness Framework v2 (Apr 2025). *Lab primary source.*
4. SentinelOne, "Bring Your Own Vulnerable Driver: How EDR Killing Became an Industry". *Vendor incident-response data.*
5. Apple Platform Security, "Uses for Optic ID, Face ID, and Touch ID". *Vendor documentation.*
6. Anthropic with Pattern Labs, "Confidential Inference via Trusted Virtual Machines" (June 2025). *Vendor research design.*
7. Arce-Caliskan, Fuller et al., "Sample-then-Correct" fuzzy extractors (IACR ePrint 2026/1930). *Academic preprint.*
8. FTC Bureau of Economics, staff report on emergency technology at ATMs (2010). *Government report.*
9. Coinkite, Coldcard documentation: "Trick PINs". *Vendor documentation.*
10. European Commission, Guidelines on prohibited AI practices under the AI Act, C(2025) 5052 final (July 2025). *Official, non-binding guidance.*
11. Frontier Model Forum, "Foundational Security Practices" issue brief (July 2024). *Industry body.*
12. Microsoft Learn, "Windows Hello Enhanced Sign-in Security". *Vendor documentation.*
13. IETF RFC 9334, "Remote ATtestation procedureS (RATS) Architecture" (Jan 2023). *Standards document (Informational).*
14. Thales Luna HSM documentation, "M of N secret sharing". *Vendor documentation.*
15. Entrust nShield Security World v13.3, Security Manual: access control. *Vendor documentation.*
16. Biometric Update, "NIST FRTE 1:1 shows facial verification accuracy converging" (Aug 2026). *Trade-press summary of NIST results.*
17. Deutschmann & Lindholm, continuous authentication with behavioral biometrics (BIOSIG 2013). *Peer-reviewed.*
18. Mondal & Bours, keystroke-plus-mouse continuous authentication (ISBA 2015), CPS-VO record. *Peer-reviewed (record page).*
19. NIST SP 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management. *Government standard.*
20. iProov, Threat Intelligence Report 2025 (press release, Feb 2025). *Vendor threat data.*
21. FIDO Alliance, Biometrics Requirements v4.1 (Jan 2025). *Certification specification.*
22. CEN/TS 18099:2024, Biometric data injection attack detection (preview via ANSI webstore). *Standard (preview).*
23. Apple Platform Security, "Biometric security". *Vendor documentation.*
24. Schmidt et al., "Introducing WESAD" (ICMI 2018). *Peer-reviewed (lab study).*
25. Toshnazarov et al., SOSW smartwatch stress detection (KAIST, 2024). *Peer-reviewed (lab and field).*
26. D'Mello & Booth, "Affect detection from wearables in the wild". *Academic paper on a government field program.*
27. National Research Council, "The Polygraph and Lie Detection" (2003). *National Academies report.*
28. Axelsson, "The Base-Rate Fallacy and the Difficulty of Intrusion Detection" (ACM TISSEC, 2000). *Peer-reviewed.*
29. Clark & Hengartner, "Panic Passwords: Authenticating under Duress" (USENIX HotSec 2008). *Peer-reviewed.*

30. US Air Force Instruction 91-104, Nuclear Surety Tamper Control and Detection Programs. *Government instruction (PDF mirror).*
31. EDPB Opinion 11/2024 on facial recognition to streamline airport passenger flows (May 2024). *Regulator opinion.*
32. CNIL, "La biométrie sur les lieux de travail" (model regulation 2019-001). *Regulator guidance.*
33. Duane Morris Class Action Defense Blog on Barnett v. Apple (Ill. App. Ct., 2022). *Law-firm case summary.*
34. Casa documentation, "Inheritance". *Vendor documentation.*
35. Vitalik Buterin, "Why we need wide adoption of social recovery wallets" (2021). *Design essay.*
36. Bitwarden Help, "Emergency Access". *Vendor documentation.*
37. BioSpace / Thermo Fisher, "FBI approves Thermo Fisher Scientific's Rapid DNA solution for law enforcement booking stations". *Vendor press release.*
38. UNH Today, touch-DNA transfer study (Mar 2024). *University release on research.*
39. O'Connor et al., kinship analysis with additional STR loci (NIST/Promega proceedings, 2010). *Government scientific presentation.*
40. US EEOC, Fact sheet on the Genetic Information Nondiscrimination Act. *Government guidance.*
41. AWS CloudHSM User Guide, "Quorum authentication". *Vendor documentation.*
42. Microsoft Learn, "Manage emergency access accounts in Microsoft Entra ID" (updated June 2026). *Vendor documentation.*
43. Anthropic, Responsible Scaling Policy updates log (RSP v2.2, May 2025). *Lab primary source.*
44. Anthropic, Responsible Scaling Policy v3.0 (effective Feb 2026). *Lab primary source.*
45. US Department of Justice, "Former Google engineer found guilty of economic espionage and theft of confidential AI technology" (Jan 30, 2026). *Government press release.*
46. CBS News San Francisco, coverage of charges against Linwei Ding. *Secondary news coverage (allegation).*
47. VentureBeat, "Senators send letter questioning Mark Zuckerberg over Meta's LLaMA leak" (2023). *News coverage.*
48. Jameson Lopp, "Wrench Attacks" talk transcript (Bitcoin 2025). *Secondary (conference talk; different population).*
49. Houses of the Oireachtas, written answer on tiger kidnappings (10 Nov 2009). *Parliamentary record; only partially verified (search excerpts).*
50. Microsoft Learn, "Continuous access evaluation". *Vendor documentation.*
51. Teleport, "Teleport multi-factor authentication" guide. *Vendor documentation.*
52. Bojinov, Sanchez, Reber, Boneh, Lincoln, "Neuroscience Meets Cryptography" (USENIX Security 2012). *Peer-reviewed.*
53. Facephi, "Presentation attack vs. injection attack". *Vendor blog.*
54. Insurance Business, "Deepfake video conference sees criminals escape with US$25 million". *Secondary news coverage.*
55. The Record, "Windows Hello bypassed using infrared image" (CyberArk, CVE-2021-34466, 2021). *News coverage of security research.*
56. The Register, "Windows Hello fingerprint authentication bypassed" (Blackwing Intelligence, Nov 2023). *News coverage of security research (patched).*
57. TEE.fail project site (IEEE S&P 2026; disclosed Oct 2025). *Academic research disclosure.*
58. SecurityWeek, "New attack targets DDR5 memory to steal keys from Intel and AMD TEEs". *News coverage of security research.*
59. Apple Support 120340, "About Stolen Device Protection for iPhone". *Vendor documentation.*

60. Cyber Security Agency of Singapore, Advisory AD-2025-018. *Government advisory.*
61. The Register, "Windows Hello, hell no" (ERNW research at Black Hat 2025, Aug 2025). *News coverage of security research.*
62. Nextgov/FCW, "US AI labs are emerging target for foreign spies, experts warn Congress" (July 2026). *Secondary news coverage of testimony.*
63. CNN, "China-linked hackers impersonated US AI insiders" (Oct 2026). *Secondary news coverage of Proofpoint research.*
64. SecureAuth documentation, "Continuous facial authentication" (SessionGuardian). *Vendor documentation / claim.*
65. OLOID, "Continuous authentication and presence detection". *Vendor marketing.*
66. Android Open Source Project, "Biometrics". *Vendor documentation.*
67. Yubico, "Getting a biometric security key right". *Vendor claim.*
68. Apple Platform Security, "Face ID, Touch ID, passcodes, and passwords". *Vendor documentation (accuracy figures are vendor claims).*
69. NVIDIA Attestation documentation, Hopper single-GPU example. *Vendor documentation.*
70. NVIDIA, Confidential Containers reference architecture overview. *Vendor documentation.*
71. NVIDIA blog, "Azure confidential VMs with NVIDIA H100 generally available" (Sept 2024). *Vendor announcement.*
72. Google Cloud blog, "From clicks to clusters: confidential computing expands with Intel TDX". *Vendor announcement.*
73. arXiv 2409.03992, confidential-computing performance of H100 LLM inference. *Academic preprint.*
74. Fortanix, "Fortanix Confidential AI protects proprietary model IP" (Mar 2026). *Vendor press release.*
75. Teleport documentation, access controls guides (per-session MFA, moderated sessions, dual authorization). *Vendor documentation.*
76. arXiv 2603.00178, TEE-based process attestation of human authorship. *Academic preprint.*
77. Defense One, "Continuous multifactor biometric ID is coming to DoD" (Feb 2019). *News coverage (older; production status unknown).*
78. Blanton & Aliasgari, analysis of secure sketches for biometrics (SciTePress, 2011). *Peer-reviewed.*
79. arXiv 1304.7386, fuzzy vault correlation and record-multiplicity attacks. *Academic preprint.*
80. arXiv 2405.04463, World iris-code uniqueness via secure multiparty computation. *Academic preprint (vendor-affiliated).*
81. ID Tech Wire, "Anonybit secures patent for decentralized biometric authentication". *Trade press (vendor claims).*
82. Fireblocks, "What is MPC". *Vendor claim.*
83. NIST CSRC Glossary, "Two-Person Integrity" (CNSSI 4009). *Government glossary.*
84. arXiv 2504.15181, analysis of frontier AI security commitments and the EU GPAI Code drafts. *Academic preprint (quotes G42 framework).*
85. SL5 Task Force, "Releasing the SL5 Standard v0.1" (Mar 2026). *Nonprofit draft standard (public summary).*
86. Evidian, Natixis finger-vein case study. *Vendor case study.*
87. 21 CFR 11.200, Electronic signature components and controls (Cornell LII). *US regulation.*
88. NIST FIPS 140-2, Security Requirements for Cryptographic Modules. *Government standard (level definitions carried into FIPS 140-3).*
89. Sophos Naked Security, "Windows Hello face recognition spoofed with photographs" (Jan 2018). *News coverage of security research.*

90. Palmetshofer, Findling, Kurz, continuous face authentication with temporal trust decay (arXiv 2608.00763, Aug 2026). *Academic preprint (abstract read).*
91. The Register, "Gummi bears defeat fingerprint sensors" (Matsumoto, 2002). *News coverage of research.*
92. New York Labor Law § 201-a. *Statute.*
93. Fujitsu, PalmSecure-F Pro datasheet. *Vendor claim.*
94. Amazon, "Generative AI trains Amazon One palm scanning technology". *Vendor claim.*
95. Security Affairs, "Hackers bypass vein-based authentication with a wax hand" (CCC, Dec 2018). *News coverage of security research.*
96. Fulcrum Biometrics, Fujitsu PalmSecure F-Pro mouse listing. *Reseller listing.*
97. Fulcrum Biometrics, Fujitsu PalmSecure F-Pro listing. *Reseller listing (price).*
98. Hitachi, VeinID H-1 finger-vein scanner. *Vendor claim.*
99. arXiv 2308.03189, IrisCode false-match rates at scale. *Academic preprint.*
100. BleepingComputer, "Samsung Galaxy S8 iris scanner fooled by a photo" (CCC, 2017). *News coverage of security research.*
101. Pharmaceutical Technology, sponsored interview with Nymi CEO (Nov 2020). *Vendor claim (sponsored content).*
102. arXiv 2003.03273, "Heartbeats in the Wild". *Academic preprint.*
103. Eberz et al., "Broken Hearted: How To Attack ECG Biometrics" (NDSS 2017). *Peer-reviewed.*
104. Electronics Specifier, "Forget fingerprints, you can pay with your heartbeat" (original Nymi band). *Trade press.*
105. TypingDNA, banking/PSD2 one-pager. *Vendor claim.*
106. arXiv 2609.29851, eight-week fixed-text keystroke template ageing study (Sept 2026). *Academic preprint.*
107. Mondal & Bours, mouse-dynamics continuous authentication (BIOSIG 2013). *Peer-reviewed.*
108. Lohr & Komogortsev, "Eye Know You" (IEEE T-BIOM 2022). *Peer-reviewed.*
109. arXiv 2501.17866, longitudinal EEG authentication study (2025). *Academic preprint.*
110. Alecci et al., replication of PPG biometrics (Sensors, 2025). *Peer-reviewed.*
111. Ryu et al., "Continuous multimodal biometric authentication schemes: a systematic review" (IEEE Access, 2021). *Peer-reviewed review.*
112. DARPA, Active Authentication program page. *Government program page.*
113. Microsoft Learn, "Presence sensing: wake on approach and lock on leave". *Vendor documentation.*
114. iBeta, ISO/IEC 30107-3 PAD confirmation letters (test parameters). *Accredited test lab.*
115. iBeta, "Biometrics: ISO PAD and FIDO comparison" (2022). *Accredited test lab.*
116. FIDO Alliance, Biometrics Requirements v5.0 draft rd02 (Sept 2026). *Draft certification specification.*
117. Biometric Update, "EAB previews biometric injection attack detection standardization developments" (July 2026). *Trade press (secondary).*
118. ISO, ISO/IEC 25456 Biometric data injection attack detection (project page). *Standards project (draft).*
119. The Register, "Apple iSight webcam LED hack" (iSeeYou research, Dec 2013). *News coverage of security research.*
120. Frontpoint Help Center, "Panel duress". *Vendor documentation.*
121. FingerTec training material, duress finger feature. *Vendor documentation.*

22. GrapheneOS, Features overview (duress PIN/password). *Project documentation.*
23. IFIP / HAL hal-04292389, transfer of WESAD-trained EDA stress models. *Peer-reviewed.*
24. NIJ/OJP, "Voice stress analysis: only 15 percent of lies about drug use detected" (2007 study). *Government-funded field study.*
25. Harnsberger, Hollien et al., "Stress and deception in speech: evaluating layered voice analysis" (J. Forensic Sci., 2009). *Peer-reviewed (abstract).*
26. US GAO, GAO-14-159 highlights: TSA behavior detection (2013). *Government audit.*
27. Jordan et al., test of the Micro-Expressions Training Tool (2019). *Peer-reviewed.*
28. Sun, Paredes, Canny, "MouStress" (CHI 2014). *Peer-reviewed.*
29. arXiv 2111.09243, keystroke dynamics and HRV for emotion and stress. *Academic preprint.*
30. PrivacyScout, shoulder-surfing risk estimation (PoPETs 2022). *Peer-reviewed.*
31. US Patent 7,623,674, stereo-vision anti-tailgating portal. *Patent.*
32. Gupta & Gao, coercion-resistant keys from voice and skin conductance (USENIX Security 2010). *Peer-reviewed.*
33. medRxiv 2024.08.22.24312398, review of electrodermal activity confounds. *Preprint review.*
34. Sargent & Greenleaf, electronic vault lock product page. *Vendor documentation.*
35. CTV News Toronto, "Special safes led to a dramatic drop in pharmacy robberies in Toronto: police". *News coverage of police data (uncontrolled before/after).*
36. Alberta College of Pharmacy, "An effective deterrent" (Jan 2022). *Professional regulator article (reported, uncontrolled figures).*
37. National Bank of Belgium, cash-in-transit and intelligent banknote neutralisation. *Central bank.*
38. Möser, Eyal, Sirer, "Bitcoin Covenants" (2016). *Peer-reviewed.*
39. Juels, Catalano, Jakobsson, "Coercion-Resistant Electronic Elections" (IACR ePrint 2002/165). *Peer-reviewed.*
40. Czeskis, Kohno, Schneier et al., "Defeating Encrypted and Deniable File Systems" (USENIX HotSec 2008). *Peer-reviewed.*
41. NDSS 2024 paper on honeywords (Bernoulli honeywords). *Peer-reviewed.*
42. 1Password blog, "Introducing Travel Mode" (2017). *Vendor documentation.*
43. SatoshiLabs, SLIP-0039: Shamir's Secret-Sharing for Mnemonic Codes. *Specification.*
44. Coincover, "Ledger Recover". *Vendor documentation.*
45. Unchained, Inheritance Protocol (blog). *Vendor documentation.*
46. Ethereum IPTF, social recovery pattern. *Secondary pattern catalogue.*
47. Google Account Help, "About Inactive Account Manager". *Vendor documentation.*
48. BitBox blog, "Exploring Bitcoin miniscript with Liana and the BitBox02". *Vendor blog.*
49. BIP 112, OP_CHECKSEQUENCEVERIFY. *Protocol specification.*
50. Apple Support 102631, "How to add a Legacy Contact for your Apple Account". *Vendor documentation.*
51. Bitwarden Help, "Add and manage trusted emergency contacts". *Vendor documentation.*
52. BIP 345, OP_VAULT (withdrawn May 2025). *Protocol proposal.*
53. Apple Support 102381, "About Face ID advanced technology". *Vendor documentation.*

54. Regulation (EU) 2016/679, General Data Protection Regulation (EUR-Lex). *EU law.*
55. Anthropic, "Frontier Model Security" (July 2023). *Lab primary source.*
56. IANA, Root KSK Ceremony 13. *Primary ceremony record.*
57. NANOG50, "DNSSEC for the Root Zone" presentation (2010). *Primary presentation (2010 design).*
58. UpGuard, NIST SP 800-53 PS-4 Personnel Termination summary. *Secondary summary of control text.*
59. Regulation (EU) 2024/1689, Artificial Intelligence Act (EUR-Lex). *EU law.*
60. Garrigues, "AI Digital Omnibus Regulation has been published" (2026). *Law-firm summary.*
61. Wolters Kluwer Global Workplace Law & Policy, "The prohibition of AI emotion recognition technologies in the workplace under the AI Act". *Legal commentary.*
62. AI Act Annex III (artificialintelligenceact.eu). *EU law (unofficial reproduction).*
63. Article 29 Working Party, Guidelines on consent (WP259). *Regulator guidance (PDF mirror).*
64. AKD, "The Dutch GDPR implementation act and the use of biometric data". *Law-firm summary.*
65. IAPP, "Dutch DPA issues record 725K euro fine for GDPR violations" (2020). *Trade press.*
66. PwC Legal Belgium, Belgian DPA fines employer EUR 45,000 (2024). *Law-firm summary.*
67. EDPB-EDPS Joint Opinion 2/2026 on the Digital Omnibus. *Regulator opinion.*
68. Illinois Biometric Information Privacy Act, 740 ILCS 14. *Statute (page not fetched during research).*
69. FreightWaves, "Settlement of case involving BNSF's use of trucker biometrics set at $75M". *News coverage.*
70. Constangy, "After 16 years, BIPA is amended to limit potential damages". *Law-firm summary.*
71. Paul Hastings, "7th Circuit confirms BIPA amendment has retroactive application" (Clay v. Union Pacific, Apr 2026). *Law-firm summary.*
72. Robbins Geller, landmark $650 million Facebook biometric settlement approved (2021). *Plaintiffs' firm release.*
73. Bloomberg Law, "BNSF settles Illinois biometric privacy case for $75 million". *News coverage.*
74. Cybersecurity Law Report, Texas AG billion-dollar settlement with Google. *Legal trade press.*
75. Littler, "Implications for employers of Colorado's new biometrics law" (HB24-1130). *Law-firm summary.*
76. Revised Code of Washington 19.375.020, Biometric identifiers. *Statute.*
77. New York Senate Bill S681 (2025–26). *Pending bill.*
78. Holland & Knight, "New York law requires notice of employees' electronic monitoring" (2022). *Law-firm summary.*
79. White & Case, "CPPA finalizes rules on ADMT, risk assessments and cybersecurity audits" (2025). *Law-firm summary.*
80. Wolters Kluwer Global Workplace Law & Policy, "Everywhere at once: the Digital Omnibus and the missing protection for workers". *Legal commentary.*
81. Epoch AI, "Models over 10^25 FLOP". *Research data.*
82. Cloud Security Alliance, research note on CAISI frontier AI testing agreements (2026). *Industry research note (secondary).*
83. Morgan Lewis, "America's AI Action Plan encourages reforms for rapid data center buildout" (July 2025). *Law-firm summary.*
84. AFPI written testimony to the House Select Committee on the CCP (Apr 16, 2026). *Congressional testimony (quotes VentureBeat, 2023).*
85. Mayer Brown, "California enacts SB 53" (Oct 2025). *Law-firm summary (statute text not read).*

186. Wiley, "New York finalizes RAISE Act for frontier AI models; law takes effect January 1, 2027". *Law-firm summary.*

187. EU GPAI Code of Practice, Safety & Security chapter (final, July 2025), via code-of-practice.ai. *Unofficial mirror of the final text.*

188. RAND, "Achieving AI Model Weight Security Level 3" (RR-A4704-1, Aug 2026). *Think-tank report (search listing only; full text not read).*

189. Virtualization Review, "OpenAI slows frontier AI training after Hugging Face breach, adds new safeguards" (Aug 2026). *Secondary news coverage.*

190. Frontier Risk (Substack), on Google DeepMind Frontier Safety Framework v3.1 (2026). *Secondary commentary.*

191. GovInfoSecurity, "Meta plans to restrict high-risk AI models". *Secondary news coverage.*

192. Teleport documentation, "Hardware key support". *Vendor documentation.*

193. CyberArk, fourth-quarter and full-year 2025 results. *Company financial release.*

194. SDxCentral, "Palo Alto Networks completes $25B CyberArk deal". *Trade press.*

195. Okta Help, "Identity Threat Protection overview". *Vendor documentation.*

196. Plurilock, "Behavioral biometrics: the science". *Vendor claim.*

197. Nymi, Nymi Band product page. *Vendor documentation.*

198. Yubico, "HYPR and Yubico" (YubiKey Bio Multi-protocol Edition). *Vendor documentation.*

199. US Patent 7,856,558 B2, "Biometric verification and duress detection system". *Patent.*

200. US Patent 10,083,304, coercion scoring at biometric login with decoy data. *Patent.*

201. Global Market Insights, Privileged Access Management market report. *Third-party market research.*

202. Fortune Business Insights, Privileged Access Management market report. *Third-party market research.*

203. TechCrunch, "Irregular raises $80 million to secure frontier AI models" (Sept 2025). *News coverage.*

204. Security Level 5 (sl5.org). *Nonprofit website.*

205. US Election Assistance Commission, FIPS 140-2 Historical status policy memo (June 2026). *Government memo.*
